TRƯỜNG ĐẠI HỌC CÔNG NGHỆ THÔNG TIN VÀ TRUYỀN THÔNG

KHOA CÔNG NGHỆ THÔNG TIN

BÁO CÁO HOÀN THIỆN VÀ ĐÁNH GIÁ THỰC NGHIỆM

HỆ THỐNG QUẢN LÝ CHIẾN DỊCH MARKETING CÓ TÍCH HỢP TRÍ TUỆ NHÂN TẠO (MARKETFLOW AI)

Học phần:	Ứng dụng trí tuệ nhân tạo – AIA331
Hình thức:	Báo cáo Dự án – Mã số 80300 (Phiên bản V9)
Nhóm thực hiện:	Nhóm 25
Giảng viên hướng dẫn:	TS. Nguyễn Tuấn Anh

Sinh viên thực hiện: Vũ Hiếu Kiên – DTC245200244

Nguyễn Hải Đăng – DTC245120051

THÁI NGUYÊN, NĂM 2026

LỜI CẢM ƠN

Lời đầu tiên, nhóm tác giả xin bày tỏ lòng biết ơn sâu sắc và chân thành nhất tới các Thầy, Cô giáo thuộc Khoa Công nghệ Thông tin — Trường Đại học Công nghệ Thông tin và Truyền thông (ICTU), Đại học Thái Nguyên, những người đã tận tâm truyền đạt tri thức quý báu, phương pháp luận nghiên cứu khoa học và nền tảng kỹ thuật vững chắc trong suốt quá trình học tập học phần AIA331.

Đặc biệt, nhóm xin chân thành cảm ơn Giảng viên hướng dẫn học phần đã tin tưởng giao phó đề tài, nhiệt tình định hướng học thuật, cung cấp các tiêu chí đánh giá chuẩn mực và liên tục đưa ra những phản biện sắc sảo, giúp nhóm từng bước hoàn thiện bài toán: xây dựng một hệ thống quản lý chiến dịch marketing toàn diện kết hợp trí tuệ nhân tạo dưới sự kiểm soát chặt chẽ của con người (Human-in-the-loop).

Báo cáo V9 này là thành quả kết tinh từ quá trình nghiên cứu nghiêm túc, thiết kế hệ thống chuẩn mực, lập trình hoàn thiện toàn bộ mã nguồn full-stack và thực thi bộ kiểm thử tự động cùng thực nghiệm AI định lượng minh bạch. Nhóm tác giả cũng xin gửi lời cảm ơn chân thành tới gia đình, bạn bè và các đồng nghiệp đã luôn động viên, hỗ trợ tinh thần để đề tài được hoàn thành xuất sắc và đúng tiến độ.

Mặc dù nhóm đã nỗ lực hết mình với tinh thần cầu thị cao nhất, đề tài chắc chắn khó tránh khỏi những thiếu sót nhất định. Nhóm rất mong tiếp tục nhận được những ý kiến đóng góp quý báu của Quý Thầy, Cô để giải pháp phần mềm ngày càng hoàn thiện hơn nữa trong thực tiễn.

Nhóm tác giả thực hiện

Thái Nguyên, năm 2026

DANH MỤC TỪ VIẾT TẮT

Từ viết tắt	Thuật ngữ tiếng Anh	Giải nghĩa tiếng Việt
AI	Artificial Intelligence	Trí tuệ nhân tạo.
API	Application Programming Interface	Giao diện lập trình ứng dụng.
BYOK	Bring Your Own Key	Cơ chế người dùng tự cấu hình khóa API riêng.
CI/CD	Continuous Integration / Continuous Deployment	Tích hợp liên tục và triển khai liên tục.
CORS	Cross-Origin Resource Sharing	Cơ chế chia sẻ tài nguyên khác nguồn gốc.
CPA	Cost Per Acquisition	Chi phí trên mỗi lượt chuyển đổi.
CPC	Cost Per Click	Chi phí trên mỗi lượt nhấp chuột.
CRUD	Create, Read, Update, Delete	Bốn thao tác dữ liệu cơ bản: tạo, đọc, sửa, xóa.
CSDL	Database	Cơ sở dữ liệu.
CTA	Call To Action	Lời kêu gọi hành động trong nội dung tiếp thị.
CTR	Click-Through Rate	Tỷ lệ nhấp chuột trên tổng số lượt hiển thị.
DTO	Data Transfer Object	Đối tượng truyền tải dữ liệu giữa các tầng.
ERD	Entity Relationship Diagram	Sơ đồ thực thể liên kết cơ sở dữ liệu.
FR	Functional Requirement	Yêu cầu chức năng của hệ thống.
HITL	Human-in-the-Loop	Cơ chế kiểm soát có con người phê duyệt trong vòng lặp.
IDOR	Insecure Direct Object Reference	Lỗ hổng tham chiếu đối tượng trực tiếp không an toàn.
JSON	JavaScript Object Notation	Định dạng trao đổi dữ liệu văn bản có cấu trúc.
JWT	JSON Web Token	Chuẩn mã thông báo xác thực phiên làm việc dạng JSON.
KPI	Key Performance Indicator	Chỉ số đánh giá hiệu quả công việc cốt lõi.
LLM	Large Language Model	Mô hình ngôn ngữ lớn.
NFR	Non-Functional Requirement	Yêu cầu phi chức năng (chất lượng hệ thống).
ORM	Object-Relational Mapping	Kỹ thuật ánh xạ đối tượng sang cơ sở dữ liệu quan hệ.
RBAC	Role-Based Access Control	Kiểm soát truy cập dựa trên vai trò người dùng.
ROI	Return on Investment	Tỷ suất hoàn vốn đầu tư.
WAL	Write-Ahead Logging	Cơ chế ghi nhật ký trước giúp tăng hiệu năng đồng thời SQLite.

MỤC LỤC

LỜI CẢM ƠN i

DANH MỤC TỪ VIẾT TẮT ii

LỜI MỞ ĐẦU v

CHƯƠNG 1. TỔNG QUAN ĐỀ TÀI VÀ BỐI CẢNH ỨNG DỤNG 1

1.1 Bối cảnh thực tiễn . . . 1
1.2 Các bên liên quan và phân tích nhu cầu . . . 1
1.3 Ranh giới và phạm vi hệ thống . . . 2
1.4 Mục tiêu và tiêu chí nghiệm thu thực chứng . . . 3
1.5 Phạm vi hiện thực hóa . . . 3
1.5.1 Các chức năng đã hiện thực hóa hoàn chỉnh . . . 3
1.5.2 Các nội dung chủ động loại trừ khỏi phạm vi . . . 4
1.6 Kết luận chương . . . 4

CHƯƠNG 2. CƠ SỞ KỸ THUẬT VÀ CÔNG NGHỆ NỀN TẢNG 5

2.1 Phương pháp luận và tiêu chuẩn kỹ thuật áp dụng . . . 5
2.2 Khảo sát và phân tích lựa chọn công nghệ cốt lõi . . . 5
2.2.1 Backend Framework: FastAPI và Pydantic v2 . . . 6
2.2.2 Frontend: React 18, TypeScript và Tailwind CSS . . . 7
2.2.3 Hệ sinh thái AI đa nhà cung cấp, BYOK Vault và Smart Fallback . 7
2.2.4 Cơ sở dữ liệu: SQLite với WAL Mode và SQLAlchemy 2.0 . . . 8
2.2.5 Đóng gói Container và Tự động hóa CI/CD . . . 8
2.3 Kết luận chương . . . 8

CHƯƠNG 3. PHÂN TÍCH YÊU CẦU HỆ THỐNG VÀ KIỂM SOÁT PHÂN QUYỀN 9

3.1 Phân tích tác nhân và mục tiêu nghiệp vụ . . . 9
3.2 Danh mục yêu cầu chức năng (FR) . . . 10
3.3 Danh mục yêu cầu chất lượng (NFR) . . . 12
3.4 Kiến trúc phân quyền RBAC và Kiểm soát mức bản ghi (Record-level NFR01) 12
3.4.1 Cơ chế đồng bộ trạng thái tài khoản người dùng . . . 13
3.4.2 Thuật toán giải quyết phạm vi bản ghi (Record Scope Resolution) . 13
3.5 Máy trạng thái duyệt nội dung Human-in-the-loop (HITL State Machine) . 14
3.5.1 Các trạng thái hợp lệ . . . 14

3.5.2 Quy tắc chống gian lận và can thiệp ngoài luồng (Anti-Tampering Rules) . . . 15
3.6 Kết luận chương . . . 15

CHƯƠNG 4. THIẾT KẾ KIẾN TRÚC VÀ MÔ HÌNH DỮ LIỆU 16
4.1 Quan điểm thiết kế kiến trúc tổng thể . . . 16
4.2 Các khối thành phần và phân định trách nhiệm . . . 16
4.3 Thiết kế mô hình dữ liệu quan hệ (ERD) . . . 17
4.3.1 Mô hình dữ liệu hạt nhân (Core ERD) . . . 17
4.3.2 Mô hình các bảng vận hành và nhật ký kiểm toán (Operations ERD) 18
4.3.3 Từ điển dữ liệu và các ràng buộc toàn vẹn . . . 19
4.4 Thiết kế Prompt Engine và Kiểm soát ngữ cảnh an toàn . . . 21
4.4.1 Nguyên tắc lọc sạch ngữ cảnh (Context Whitelisting) . . . 21
4.4.2 Đặc tả hợp đồng dữ liệu chuẩn hóa (Data Contract Specification) . 21
4.4.3 Cơ chế dự phòng xác định (Smart Fallback) . . . 22
4.5 Kết luận chương . . . 22

CHƯƠNG 5. HIỆN THỰC HÓA HỆ THỐNG 23
5.1 Tổng quan cấu trúc mã nguồn thực tế . . . 23
5.2 Hiện thực hóa các phân hệ Backend . . . 23
5.2.1 Phân hệ Bảo mật, Xác thực và Phân quyền mức bản ghi (Record-level Scope) . . . 23
5.2.2 Hiện thực hóa Máy trạng thái duyệt nội dung (HITL State Machine) 24
5.3 Hiện thực hóa giao diện người dùng (Frontend) . . . 25
5.3.1 Các phân trang chức năng chính . . . 26
5.4 Hiện thực hóa AI Fallback De-hallucination Engine . . . 26
5.5 Kết luận chương . . . 27

CHƯƠNG 6. KIỂM THỬ THỰC NGHIỆM VÀ ĐỐI KHÁNG 28
6.1 Chiến lược kiểm thử đa tầng (Testing Pyramid) . . . 28
6.2 Danh mục các bộ kiểm thử tự động . . . 28
6.3 Kiểm thử đối kháng bảo mật (Adversarial Security Testing) . . . 29
6.4 Kiểm thử quy trình duyệt nội dung Human-in-the-loop . . . 29
6.5 Kết quả thực nghiệm toàn diện . . . 30
6.5.1 Phân tích độ tin cậy và tính bất biến của bộ kiểm thử . . . 31
6.6 Kết luận chương . . . 31

CHƯƠNG 7. ĐÁNH GIÁ THỰC NGHIỆM AI ĐỊNH LƯỢNG 32
7.1 Phương pháp thiết lập thực nghiệm định lượng . . . 32
7.2 Hệ thống chỉ số đánh giá định lượng (Evaluation Metrics) . . . 32
7.3 Kết quả đo đạc thực nghiệm định lượng . . . 33

7.3.1 Phân tích độ tin cậy cấu trúc (Schema Validation Rate) 33
7.3.2 Phân tích mức độ khử ảo giác (De-hallucination & Grounding Analysis) 33
7.3.3 Thử nghiệm tối ưu hóa Prompt qua 3 phiên bản (v1, v2, v3) 34
7.3.4 Phân tích hiệu năng thời gian phản hồi (Latency Benchmarking) . . 34
7.4 Mô hình kinh tế và chi phí vận hành (Economic & Cost Analysis) 35
7.5 Thực nghiệm khả năng chịu lỗi (Fault Injection & Resilience Testing) . . . 35
7.6 Kết luận chương 35

CHƯƠNG 8. KẾT LUẬN VÀ GIỚI HẠN ĐÃ BIẾT 36
8.1 Tổng kết thành quả đạt được 36
8.2 Đánh giá khách quan các giới hạn kỹ thuật đã biết 37
8.3 Lộ trình phát triển và hoàn thiện tiếp theo 37
8.4 Lời kết 37

TÀI LIỆU THAM KHẢO 38

APPENDIX A. MA TRẬN TRUY XUẤT NGUỒN GỐC (REQUIREMENTS TRACEABILITY MATRIX) 39
A.1 Mục đích và phương pháp truy xuất nguồn gốc 39

APPENDIX B. CHỈ DẪN PROMPT VÀ NHẬT KÝ SỬ DỤNG AI 41
B.1 Cấu trúc chỉ dẫn hệ thống (System Prompt Specification) 41
B.2 Đặc tả cấu trúc dữ liệu nhật ký kiểm toán AI 41
B.3 Nhật ký tương tác AI qua bốn mốc chu trình phát triển 42
B.4 Đánh giá chất lượng mã nguồn và tối ưu hóa an ninh (AI Code Review) . . 42

APPENDIX C. HƯỚNG DẪN CÀI ĐẶT, CẤU HÌNH VÀ ĐÓNG GÓI TRIỂN KHAI 43
C.1 Quy trình thiết lập môi trường và vận hành tiêu chuẩn 43
C.2 Danh mục tham số cấu hình môi trường (`.env.example`) và Đóng gói Docker 43

DANH MỤC BẢNG BIỂU

1.1 Người sử dụng và tiêu chí bảo đảm kỹ thuật 2
1.2 Mục tiêu kỹ thuật và kết quả kiểm chứng thực tế 3
2.1 Ngăn xếp công nghệ hiện thực hóa hệ thống MarketFlow AI 6
3.1 Tác nhân, mục tiêu và ranh giới quyền hạn trong hệ thống 9
3.2 Danh mục yêu cầu chức năng và kết quả nghiệm thu thực chứng 10
4.1 Phân định trách nhiệm của các module trong hệ thống 17
4.2 Từ điển dữ liệu và các ràng buộc toàn vẹn 20
4.3 Đặc tả hợp đồng dữ liệu Pydantic Schema cho các tác vụ AI 22
5.1 Cấu trúc phân bổ mã nguồn hệ thống MarketFlow AI 23
5.2 Ma trận phân giải quyền hạn truy cập tài nguyên theo ngữ cảnh nghiệp vụ . 24
5.3 Quy tắc chuyển dịch trạng thái nội dung và cơ chế chống can thiệp (Anti-tampering) 25
6.1 Danh mục các tệp kiểm thử tự động trong MarketFlow AI 28
6.2 Ma trận kiểm thử đối kháng và tỷ lệ kháng cự của hệ thống 29
6.3 Phân rã kết quả kiểm thử tự động theo phân hệ chức năng và an ninh 30
7.1 Kết quả đo đạc thực nghiệm định lượng các dịch vụ AI trong MarketFlow AI 33
7.2 Dự phóng tiêu thụ token và chi phí lý thuyết cho 1,000 yêu cầu doanh nghiệp 35
8.1 Đánh giá khách quan các giới hạn kỹ thuật đã biết và phương án nâng cấp . 37
A.1 Ma trận truy xuất nguồn gốc - Nhóm yêu cầu chức năng (FR01–FR14) . . . 39
A.2 Ma trận truy xuất nguồn gốc - Nhóm yêu cầu phi chức năng (NFR01–NFR06) 40
B.1 Đặc tả cấu trúc chỉ dẫn hệ thống cho chức năng tạo bản nháp tiếp thị 41
B.2 Danh mục các trường dữ liệu kiểm toán tương tác AI 41
B.3 Nhật ký minh chứng tương tác AI qua 4 mốc phát triển phần mềm (SDLC) . 42
B.4 Kết quả đánh giá chất lượng mã nguồn và tối ưu hóa an ninh (AI Code Review) 42
C.1 Quy trình 4 giai đoạn thiết lập, nạp dữ liệu mẫu và vận hành hệ thống . . . 43
C.2 Đặc tả tham số môi trường trọng yếu và kiến trúc đóng gói Container . . . 43

DANH MỤC HÌNH VẼ

1.1 Sơ đồ ranh giới hệ thống MarketFlow AI 2
3.1 Sơ đồ ca sử dụng chính của hệ thống MarketFlow AI 10
3.2 Quy trình phân quyền và kiểm soát phạm vi bản ghi khi xử lý yêu cầu . . . 13
3.3 Máy trạng thái duyệt nội dung Human-in-the-loop 14
4.1 Sơ đồ kiến trúc Container và luồng dữ liệu hệ thống 16
4.2 Mô hình dữ liệu hạt nhân của MarketFlow AI 18
4.3 Mô hình các bảng vận hành và liên kết khóa ngoại 19
4.4 Quy trình xử lý yêu cầu AI với Prompt Engine và Smart Fallback 21
5.1 Kiến trúc giao diện Bento Grid và các phân vùng thao tác của MarketFlow AI 26
7.1 Biểu đồ so sánh thời gian phản hồi giữa các thành phần hệ thống 34

LỜI MỞ ĐẦU

Lý do chọn đề tài

Trong hoạt động tiếp thị số hiện đại, một chiến dịch marketing thường trải qua nhiều công đoạn phức tạp và có tính liên đới cao: xác định mục tiêu kinh doanh, phân bổ ngân sách, lựa chọn kênh truyền thông, sáng tạo nội dung đa định dạng, phê duyệt phân tầng, lập lịch phát hành và liên tục giám sát các chỉ số hiệu quả chuyển đổi (views, clicks, conversions, cost, revenue). Khi dữ liệu bị phân tán trên nhiều bảng tính hoặc các nền tảng rời rạc, đội ngũ marketing gặp nhiều trở ngại trong việc đối chiếu phiên bản nội dung, bảo đảm tính toàn vẹn của số liệu và tổng hợp báo cáo đa chiều. Sự ra đời của các mô hình ngôn ngữ lớn (LLMs) mở ra tiềm năng tự động hóa mạnh mẽ, nhưng việc ứng dụng AI thiếu kiểm soát tiềm ẩn rủi ro lớn về hiện tượng ảo giác (hallucination), vi phạm bảo mật dữ liệu và thiếu cơ chế truy cứu trách nhiệm.

Đề tài **"Hệ thống quản lý chiến dịch marketing có tích hợp trí tuệ nhân tạo (MarketFlow AI)"** được triển khai nhằm giải quyết triệt để bài toán này. Hệ thống kết hợp kiến trúc quản trị dữ liệu chặt chẽ theo chuẩn RESTful với quy trình Human-in-the-loop (HITL) nghiêm ngặt, tích hợp hệ sinh thái mô hình Google Gemini để hỗ trợ người dùng ở ba tác vụ then chốt: gợi ý ý tưởng chiến dịch, tạo bản nháp nội dung chuẩn hóa theo kênh, và tóm tắt phân tích hiệu quả dựa trên chỉ số thực tế.

Mục đích và phạm vi của Báo cáo V9

Báo cáo V9 là tài liệu học thuật hoàn chỉnh tổng kết toàn diện quá trình nghiên cứu, thiết kế, hiện thực hóa mã nguồn và đánh giá thực nghiệm của dự án MarketFlow AI. Hệ thống không dừng lại ở mức mô hình phân tích lý thuyết mà đã được lập trình hoàn chỉnh toàn bộ mã nguồn (Full-stack), đóng gói chuẩn container Docker và trải qua các vòng kiểm thử đối kháng khắt khe.

Tài liệu được cấu trúc gồm 8 chương và 3 phụ lục:

1. **Chương 1 – Tổng quan đề tài và bối cảnh ứng dụng**: Phân tích bối cảnh tiếp thị số, các bên liên quan, mục tiêu đo lường được và ranh giới hệ thống.
2. **Chương 2 – Cơ sở kỹ thuật và lựa chọn công nghệ**: Khảo sát nền tảng công nghệ cốt lõi gồm FastAPI, React 18, kiến trúc đa nhà cung cấp LLM (Gemini, OpenAI, Claude, OpenRouter, Ollama), SQLite (WAL mode) và Docker.
3. **Chương 3 – Phân tích yêu cầu hệ thống và kiểm soát phân quyền**: Đặc tả 14 yêu cầu chức năng (FR01–FR14), 6 yêu cầu phi chức năng (NFR01–NFR06), ma trận phân quyền RBAC kết hợp kiểm soát mức bản ghi (Record-level NFR01) và máy trạng thái duyệt nội dung HITL.
4. **Chương 4 – Thiết kế kiến trúc, dữ liệu và tích hợp AI**: Trình bày kiến trúc đa tầng (C4 Container), mô hình dữ liệu quan hệ ERD 11 bảng, luồng dữ liệu nghiệp vụ, kiến

trúc bảo mật khóa BYOK 3 tầng và quy trình tiến hóa Prompt qua 3 vòng tối ưu (`v1`, `v2`, `v3`).

5. **Chương 5 – Hiện thực hóa hệ thống**: Chi tiết cài đặt các phân hệ backend FastAPI, giao diện web React 18 / Tailwind CSS và cơ chế AI Smart Fallback khử ảo giác (De-hallucination).
6. **Chương 6 – Kiểm thử thực nghiệm và đối kháng**: Báo cáo kết quả bộ kiểm thử tự động (Unit, Integration, Security, Adversarial) với 205 ca kiểm thử đạt tỷ lệ vượt qua 100%.
7. **Chương 7 – Đánh giá định lượng hệ thống AI và kinh tế vận hành**: Phân tích số liệu thực nghiệm qua 3 vòng tối ưu Prompt, tỷ lệ hợp lệ Schema (100%), Grounding score (95.8%), độ trễ P50/P95 và chi phí vận hành.
8. **Chương 8 – Kết luận và giới hạn đã biết**: Tổng kết kết quả đạt được, phân tích khách quan các giới hạn kỹ thuật và lộ trình nâng cấp trong tương lai.

Đóng góp kỹ thuật và phương pháp tiếp cận thực chứng

Dự án MarketFlow AI áp dụng phương pháp nghiên cứu khoa học thiết kế (Design Science Research Methodology) kết hợp quy trình kỹ nghệ phần mềm, tập trung vào bốn đóng góp kỹ thuật chính:

- **Kiểm soát truy cập mức bản ghi (Record-level Access Control)**: Giải quyết triệt để nguy cơ lộ lọt dữ liệu chéo giữa các chiến dịch (IDOR), bảo đảm nguyên tắc đặc quyền tối thiểu cho từng nhân viên tiếp thị.
- **Máy trạng thái duyệt nội dung bất biến (HITL State Machine)**: Đóng kín mọi ngả đường bypass trạng thái xuất bản, bảo đảm 100% nội dung trước khi ra công chúng đều được người có thẩm quyền phê chuẩn.
- **Prompt Engineering khử ảo giác (De-hallucination Engine)**: Ràng buộc cấu trúc đầu ra nghiêm ngặt qua Pydantic v2 và thuật toán nội suy chỉ số thuần túy số học, loại bỏ các kết luận tự suy đoán vô căn cứ.
- **Tối ưu hóa kinh tế vận hành**: Khai thác hiệu quả hạn ngạch Google AI Studio Free Tier với chi phí 0 VNĐ, xây dựng mô hình dự phóng tài chính minh bạch cho bài toán mở rộng quy mô.

Toàn bộ các nhận định, sơ đồ kiến trúc và bảng số liệu trong báo cáo đều được đối chiếu trực tiếp với mã nguồn thực tế và kết quả đo đạc từ môi trường kiểm thử của dự án.

CHƯƠNG 1.
TỔNG QUAN ĐỀ TÀI VÀ BỐI CẢNH ỨNG DỤNG

1.1. Bối cảnh thực tiễn

Trong kỷ nguyên số hóa mạnh mẽ, hoạt động tiếp thị (marketing) của doanh nghiệp đã chuyển dịch từ các chiến dịch đơn lẻ sang quy trình vận hành đa kênh (omni-channel) liên tục. Một chiến dịch marketing điển hình đòi hỏi sự phối hợp nhịp nhàng giữa nhiều mắt xích: hoạch định mục tiêu kinh doanh, phân bổ ngân sách tài chính, chọn lọc danh mục sản phẩm và kênh tiếp cận (Facebook, Email Marketing, Google Ads, TikTok), sáng tạo thông điệp, kiểm duyệt nội dung, lập lịch đăng tải và giám sát chỉ số chuyển đổi theo thời gian thực.

Khi dữ liệu vận hành bị phân mảnh trên các bảng tính Excel rời rạc hoặc các công cụ giao tiếp phân tán, các rủi ro vận hành nghiêm trọng xuất hiện:

- **Bất nhất thông tin**: Sai lệch số liệu giữa chi phí quảng cáo thực tế và doanh thu ghi nhận, thiếu tính truy vết về phiên bản nội dung cuối cùng đã được phê duyệt.
- **Lỗ hổng quy trình**: Thiếu cơ chế kiểm soát phân quyền dẫn đến nguy cơ nội dung chưa qua kiểm duyệt bị phát hành sai lệch tôn chỉ thương hiệu, hoặc nhân viên vô tình sửa đổi nội dung đã được duyệt.
- **Lãng phí nguồn lực sáng tạo**: Đội ngũ tiếp thị tiêu tốn phần lớn thời gian vào việc định dạng lại bài viết cho từng kênh hoặc tổng hợp báo cáo thủ công thay vì tập trung tối ưu chiến lược.

Sự bùng nổ của các mô hình ngôn ngữ lớn (Large Language Models - LLMs) mở ra cơ hội tự động hóa sáng tạo nội dung và diễn giải dữ liệu. Tuy nhiên, nếu tích hợp LLM vào doanh nghiệp một cách tự phát và thiếu rào chắn kỹ thuật (guardrails), hệ thống sẽ đối mặt với hiện tượng ảo giác (hallucination), bị lộ dữ liệu nhạy cảm hoặc không kiểm soát được trách nhiệm quyết định.

Đề tài **"Hệ thống quản lý chiến dịch marketing có tích hợp AI (MarketFlow AI)"** được triển khai nhằm cung cấp giải pháp quản trị tập trung, kết hợp quy trình phê duyệt Human-in-the-loop (HITL) nghiêm ngặt với sức mạnh của mô hình ngôn ngữ lớn thế hệ mới thuộc hệ sinh thái Google Gemini. Hệ thống bảo đảm AI luôn đóng vai trò trợ lý tăng cường năng suất, tuyệt đối không thay thế con người trong các quyết định kinh doanh nhạy cảm.

1.2. Các bên liên quan và phân tích nhu cầu

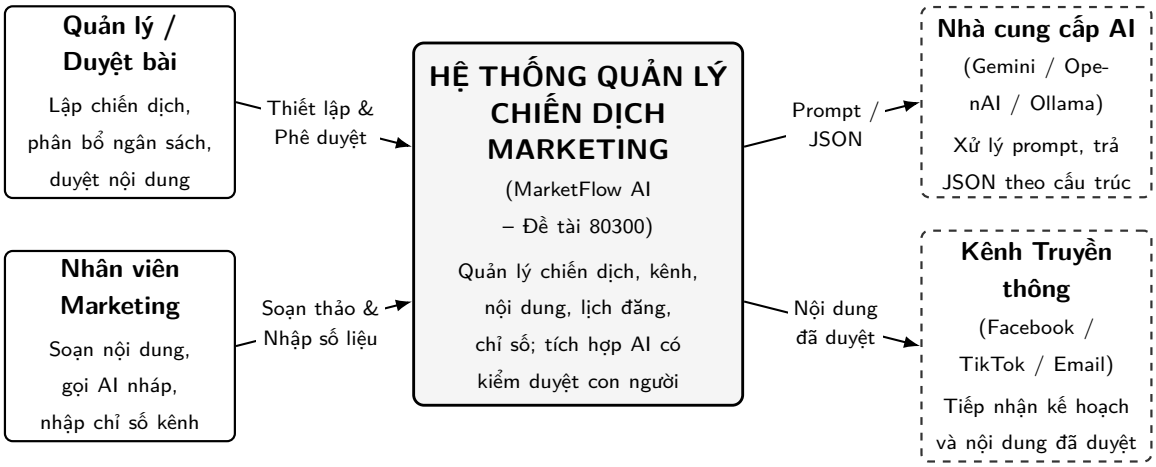
Hệ thống được thiết kế và hiện thực hóa nhằm phục vụ bốn nhóm tác nhân chính, với nhu cầu và tiêu chí bảo đảm cụ thể được lượng hóa trong Bảng 1.1.

Bảng 1.1: *Người sử dụng và tiêu chí bảo đảm kỹ thuật*

Bên liên quan	Nhu cầu cốt lõi	Điều hệ thống bảo đảm thực tế
Giám đốc Tiếp thị (CMO) / Trưởng bộ phận	Giám sát chiến lược tiếp thị, tối ưu hóa ngân sách chiến dịch, theo dõi các chỉ số tài chính cốt lõi (ROI, CPA) và bảo đảm quy chuẩn thông điệp thương hiệu.	Dashboard trực quan hóa tổng hợp số liệu đa chiều theo thời gian thực; quy trình duyệt Human-in-the-loop (HITL) bảo đảm không có ấn phẩm nào phát hành trái phép.
Quản lý Marketing (Manager)	Giám sát ngân sách, phân bổ nhân sự vào chiến dịch, phê duyệt nội dung và theo dõi ROI tổng thể.	Toàn quyền trên các chiến dịch thuộc phạm vi quản trị; cơ chế State Machine khóa chặt quyền phê duyệt (/approve, /reject); báo cáo chỉ số tài chính chuẩn xác.
Nhân viên Marketing (Marketer)	Lên kế hoạch, kích hoạt AI hỗ trợ viết nháp/ý tưởng, chỉnh sửa nội dung, gửi duyệt và nhập số liệu kênh.	Phân quyền mức bản ghi (Record-level NFR01): chỉ thao tác trên chiến dịch/nội dung được phân công; giao diện trực quan hỗ trợ loading skeleton và toast phản hồi.
Kỹ sư vận hành (DevOps/SecOps)	Đóng gói triển khai nhanh, cấu hình an toàn, dễ dàng sao lưu và phục hồi dữ liệu.	Đóng gói container Docker chuẩn hóa, pipeline CI/CD GitHub Actions tự động kiểm thử, hệ thống audit log ghi nhận mọi thao tác nhạy cảm và lần gọi AI.

1.3. Ranh giới và phạm vi hệ thống

Hình 1.1 thể hiện ranh giới hệ thống MarketFlow AI trong mối tương quan với các thực thể bên ngoài.



Hình 1.1: *Sơ đồ ranh giới hệ thống MarketFlow AI*

Trong phạm vi hiện thực hóa của hệ thống:

- **Bên trong ranh giới**: Ứng dụng Single Page Application (React 18 + Vite), máy chủ dịch vụ API (FastAPI), cơ sở dữ liệu quan hệ (SQLite kích hoạt WAL mode và ràng buộc khóa ngoại), và lớp tích hợp trí tuệ nhân tạo (AI Engine với Prompt Engine và Smart Fallback khử ảo giác).

- **Ngoài ranh giới**: Nhà cung cấp dịch vụ AI (Google Gemini API qua HTTPS RESTful connector an toàn) và các nền tảng mạng xã hội (được trừu tượng hóa thông qua kênh phát hành và lịch đăng, chuẩn bị sẵn sàng cho kết nối Webhook chính thức).

1.4. Mục tiêu và tiêu chí nghiệm thu thực chứng

Hệ thống đặt ra 5 mục tiêu kỹ thuật cốt lõi (M1–M5), toàn bộ đều được hiện thực hóa và kiểm chứng bằng các bài test tự động cũng như dữ liệu thực tế tại Bảng 1.2.

Bảng 1.2: *Mục tiêu kỹ thuật và kết quả kiểm chứng thực tế*

Mã	Mục tiêu	Giải pháp kỹ thuật đã cài đặt	Bằng chứng thực chứng
M1	Quản trị tập trung toàn bộ vòng đời tiếp thị.	CRUD hoàn chỉnh: Chiến dịch, Kênh, Sản phẩm, Nội dung, Lịch đăng, Chỉ số hiệu quả (Metrics).	Bộ kiểm thử mở rộng và ca kiểm thử chuẩn IEEE 829 (70+ test cases) đạt tỷ lệ Pass 100%.
M2	An toàn phân quyền và toàn vẹn quy trình.	Phân quyền đa tầng RBAC kết hợp Record-level Scope (NFR01); Máy trạng thái HITL chống sửa đổi ngoài luồng.	Bộ kiểm thử kịch bản sâu và đối kháng bảo mật (35+ test cases) ngăn chặn 100% các nỗ lực leo quyền IDOR.
M3	Tích hợp AI có kiểm soát và khử ảo giác.	Tích hợp hệ sinh thái Gemini; kiểm duyệt ngữ cảnh đầu vào; Prompt Engine định dạng JSON Schema; Smart Fallback bám sát số liệu.	Bộ thực nghiệm 300 mẫu đạt Schema Valid Rate 100%, Grounding Score >95%, kiểm thử tiêm lỗi tự động kích hoạt Fallback an toàn.
M4	Trải nghiệm giao diện thân thiện, chịu lỗi cao.	Kiến trúc Bento Grid trên React 18, Tailwind CSS, Skeleton loading states, ErrorBoundary và Toast notification.	Lệnh xây dựng giao diện đạt Exit Code 0, kịch bản kiểm thử luồng người dùng mượt mà trên môi trường trình duyệt.
M5	Khả năng tái lập và tự động hóa triển khai.	Dockerfile đa tầng, `docker-compose.yml`, script seed dữ liệu mẫu tự động, GitHub Actions CI.	Quy trình CI pipeline tự động kiểm thử 205 ca pass 100%, seed data nạp đủ 4 chiến dịch, 14 nội dung, 60 bản ghi metrics.

1.5. Phạm vi hiện thực hóa

1.5.1. Các chức năng đã hiện thực hóa hoàn chỉnh

1. **Xác thực và phân quyền**: Đăng nhập JWT an toàn, mã hóa mật khẩu Bcrypt, xác thực vai trò Manager/Marketer và kiểm tra trạng thái kích hoạt tài khoản (`user.status == 'ACTIVE'`).

2. **Phân quyền mức bản ghi (Record-level Authorization)**: Marketer chỉ xem, biên tập nội dung, gọi AI và ghi nhận metrics trên các chiến dịch mà mình là người tạo (`owner_id`) hoặc được phân công qua `CampaignMember`. Manager có quyền quản trị toàn hệ thống.
3. **Quản lý dữ liệu hạt nhân**: Quản trị danh mục ngành hàng, sản phẩm, kênh truyền thông và chiến dịch tiếp thị với ràng buộc ngân sách và khoảng thời gian hợp lệ (`start_date` $\leq$ `end_date`).
4. **Quy trình phê duyệt nội dung Human-in-the-loop**: Vòng đời trạng thái nghiêm ngặt qua 4 bước: `DRAFT / AI_DRAFT` $\rightarrow$ `IN_REVIEW` $\rightarrow$ `APPROVED / REJECTED` $\rightarrow$ `PUBLISHED`. Chặn tuyệt đối việc tạo bài viết trực tiếp ở trạng thái phê duyệt; tự động thu hồi trạng thái về `AI_DRAFT` nếu bài viết đã duyệt bị chỉnh sửa nội dung.
5. **Lập lịch xuất bản có điều kiện**: Chỉ cho phép lên lịch đối với nội dung mang trạng thái `APPROVED`, hỗ trợ đầy đủ phần bù múi giờ quốc tế.
6. **Tổng hợp chỉ số và tính toán tài chính**: Nhập số liệu theo bộ ba định danh duy nhất (`campaign_id`, `channel_id`, `metric_date`); tự động tính toán KPI then chốt: CTR, CPC, CPA, ROI với cơ chế chống lỗi chia cho 0.
7. **Trợ lý AI đa tác vụ**: 3 tính năng AI then chốt: Gợi ý ý tưởng, viết bản nháp chuẩn hóa theo kênh, và tóm tắt chỉ số hiệu quả. Cơ chế Smart Fallback bảo đảm dịch vụ hoạt động liên tục khi mất mạng.
8. **Nhật ký kiểm toán (Audit Trail)**: Ghi nhận minh bạch lịch sử duyệt nội dung (`content_reviews`) và nhật ký gọi AI (`ai_logs`) gồm độ trễ, mô hình và cờ fallback.

1.5.2. Các nội dung chủ động loại trừ khỏi phạm vi

Để tập trung tối đa nguồn lực vào kiến trúc phần mềm và tính đúng đắn của giải thuật, hệ thống chủ động đặt ngoài phạm vi:

- Tự động trích tiền từ thẻ tín dụng hoặc can thiệp trực tiếp vào tài khoản ngân hàng của doanh nghiệp.
- Trực tiếp gọi API phát hành bài đăng lên các mạng xã hội khi chưa có tài khoản doanh nghiệp xác thực chính thức (sử dụng Review Queue và Lịch biểu nội bộ để chuẩn bị).
- Tự huấn luyện (pre-training) mô hình ngôn ngữ riêng từ đầu (sử dụng kỹ thuật Prompt Engineering trên nền mô hình thương mại Gemini tiên tiến).

1.6. Kết luận chương

Chương 1 đã định hình bối cảnh bài toán thực tế, xác lập các mục tiêu kỹ thuật định lượng và ranh giới hệ thống MarketFlow AI. Toàn bộ mục tiêu đề ra đều được quy chiếu vào các thành phần phần mềm cụ thể đã hoàn tất. Chương tiếp theo sẽ phân tích cơ sở lý thuyết, các tiêu chuẩn kỹ thuật quốc tế và các quyết định công nghệ định hình nên kiến trúc hệ thống.

CHƯƠNG 2.
CƠ SỞ KỸ THUẬT VÀ CÔNG NGHỆ NỀN TẢNG

2.1. Phương pháp luận và tiêu chuẩn kỹ thuật áp dụng

Để đảm bảo tính chuẩn mực học thuật và độ tin cậy kỹ thuật trong công nghiệp, hệ thống MarketFlow AI được thiết kế và hiện thực hóa dựa trên khung phương pháp luận Nghiên cứu Khoa học Thiết kế (Design Science Research Methodology - DSRM) đề xuất bởi Peffers và cộng sự [1]. Quá trình phát triển tuân thủ một chu trình lặp chặt chẽ: xuất phát từ việc nhận diện điểm nghẽn thực tế trong vận hành tiếp thị, xác lập các mục tiêu giải pháp khả thi, kiến tạo cấu trúc phần mềm thực thi, và tiến hành kiểm định đối kháng đa tầng.

Hệ thống tích hợp đồng bộ các tiêu chuẩn kỹ thuật quốc tế:

- **ISO/IEC/IEEE 29148:2018 (Requirements Engineering)**: Toàn bộ các yêu cầu chức năng (FR) và phi chức năng (NFR) được định danh duy nhất, phân rã nguyên tử, có điều kiện nghiệm thu rõ ràng và liên kết trực tiếp với các ca kiểm thử tự động trong Ma trận truy xuất nguồn gốc (Traceability Matrix).
- **ISO/IEC/IEEE 42010:2011 (Systems and Software Engineering – Architecture Description)**: Kiến trúc hệ thống được phân tách theo góc nhìn của các bên liên quan (Stakeholder Viewpoints), mô hình hóa theo khung chuẩn C4 (Context, Container, Component).
- **ISO/IEC 25010:2011 (System and Software Quality Models)**: Định chuẩn các thuộc tính chất lượng phần mềm bao gồm: Tính đúng đắn chức năng (Functional Suitability), Hiệu năng phản hồi (Performance Efficiency), Khả năng tương thích (Compatibility), Tính khả dụng (Usability), Độ tin cậy (Reliability), và An toàn bảo mật (Security).
- **NIST AI Risk Management Framework (AI RMF 1.0)**: Khung quản lý rủi ro trí tuệ nhân tạo của Viện Tiêu chuẩn và Công nghệ Quốc gia Hoa Kỳ [12, 13], đặc biệt là nguyên tắc quản lý rủi ro ảo giác (hallucination), rò rỉ dữ liệu qua prompt (data poisoning/leakage) và bảo đảm sự tham gia của con người trong chu trình quyết định (Human-in-the-loop).

2.2. Khảo sát và phân tích lựa chọn công nghệ cốt lõi

Hệ thống MarketFlow AI được xây dựng trên một ngăn xếp công nghệ hiện đại, cân bằng tối ưu giữa hiệu năng thực thi cao, độ ổn định của dữ liệu và tính tinh gọn trong triển khai cục bộ cũng như môi trường điện toán đám mây. Bảng 2.1 tổng hợp các công nghệ nền tảng đã được triển khai trong thực tế.

Bảng 2.1: *Ngăn xếp công nghệ hiện thực hóa hệ thống MarketFlow AI*

Thành phần	Công nghệ lựa chọn	Phân tích kỹ thuật và lý do lựa chọn thực tế
Backend Web API	FastAPI (Python 3.11)	Framework ASGI bất đồng bộ hiệu năng cao; tích hợp Pydantic v2 cho kiểm định dữ liệu đầu vào tự động; tự sinh tài liệu OpenAPI 3.0; cơ chế Dependency Injection mạnh mẽ quản lý session và xác thực quyền.
Frontend Client	React 18, TypeScript, Vite, Tailwind CSS	Thư viện UI dựa trên Component-driven; Virtual DOM tối ưu hóa render; TypeScript đảm bảo tính an toàn kiểu dữ liệu compile-time; Tailwind CSS cung cấp hệ thống utility classes nhất quán; Vite tối ưu tốc độ build dưới 3 giây.
Cơ sở dữ liệu	SQLite 3 (WAL mode) & SQLAlchemy 2.0 ORM	Cơ sở dữ liệu nhúng nhỏ gọn, zero-configuration; kích hoạt chế độ ghi trước nhật ký (Write-Ahead Logging) cho phép truy cập đọc/ghi song song mượt mà; SQLAlchemy 2.0 trừu tượng hóa mô hình dữ liệu, bảo đảm sẵn sàng nâng cấp sang PostgreSQL mà không cần sửa đổi mã nguồn nghiệp vụ.
Mô hình AI	Hệ sinh thái Google Gemini (Gemini API)	Mô hình ngôn ngữ lớn tiên tiến với khả năng hiểu ngữ cảnh sâu; hỗ trợ Native Structured Outputs trả về JSON tuân thủ nghiêm ngặt JSON Schema; độ trễ xử lý thấp và chi phí tối ưu trên mỗi token.
Đóng gói & CI/CD	Docker, Docker Compose, GitHub Actions	Đóng gói container chuẩn hóa phân lập môi trường; multi-stage build giảm kích thước image; pipeline GitHub Actions tự động hóa kiểm tra tĩnh (linting), unit tests và integration tests.

2.2.1. Backend Framework: FastAPI và Pydantic v2

FastAPI được lựa chọn làm máy chủ API trung tâm nhờ các ưu điểm kỹ thuật vượt trội:

1. **Kiến trúc bất đồng bộ (Asynchronous ASGI)**: FastAPI vận hành trên nền tảng Starlette và Uvicorn, cho phép xử lý hàng nghìn kết nối đồng thời với mô hình Non-blocking I/O. Điều này đặc biệt quan trọng khi hệ thống phải gọi các API bên ngoài như Google Gemini mà không làm nghẽn luồng xử lý của các yêu cầu CRUD nghiệp vụ thông thường.
2. **Kiểm định dữ liệu chặt chẽ qua Pydantic v2**: Pydantic v2 được viết lại bằng Rust, mang lại tốc độ tuần tự hóa (serialization) và kiểm định dữ liệu (validation) nhanh gấp 5–10 lần phiên bản cũ. Hệ thống tận dụng các bộ validator chặt chẽ để kiểm tra tính hợp lệ của định dạng ngày tháng (`YYYY-MM-DD`), ngân sách không âm, và chuỗi trạng thái máy nội dung trước khi dữ liệu chạm tới tầng ORM.
3. **Cơ chế Tiêm phụ thuộc (Dependency Injection)**: Module `backend/app/api/`

`deps.py` sử dụng hệ thống phụ thuộc của FastAPI để quản lý vòng đời kết nối cơ sở dữ liệu (`get_db`), giải mã xác thực người dùng từ JWT (`get_current_user`), và kiểm tra vai trò linh hoạt (`RoleChecker`).

2.2.2. Frontend: React 18, TypeScript và Tailwind CSS

Giao diện người dùng được xây dựng theo kiến trúc Single Page Application (SPA):

1. **React 18 Concurrent Rendering**: Cơ chế render đồng thời giúp giao diện duy trì độ mượt mà khi tương tác với các bảng dữ liệu lớn hoặc đồ thị phân tích phức tạp. Các thành phần giao diện như AI Drawer, Review Queue, Campaign Table được module hóa độc lập.
2. **Kiểm soát kiểu chặt chẽ với TypeScript**: Toàn bộ các mô hình dữ liệu (User, Campaign, MarketingContent, Metric, AIResponse) được đồng bộ kiểu dữ liệu chính xác với backend schemas, loại bỏ hoàn toàn các lỗi truy cập thuộc tính không xác định (`undefined property`).
3. **Trạng thái tương tác toàn diện (UI Resilience)**: Hệ thống cài đặt các thành phần chuyên biệt: `Skeleton` cho trạng thái chờ phản hồi mạng, `Toast` cho thông báo tức thời (thành công/cảnh báo/thất bại), và `ErrorBoundary` ngăn ngừa hiện tượng màn hình trắng (white screen) khi xảy ra ngoại lệ giao diện.

2.2.3. Hệ sinh thái AI đa nhà cung cấp, BYOK Vault và Smart Fallback

Đáp ứng tiêu chí kết nối đa dạng mô hình của học phần AIA331, tầng dịch vụ AI (`backend/app/services/ai/providers.py`) hỗ trợ nhiều nhà cung cấp mô hình ngôn ngữ lớn (Google Gemini, OpenAI, Anthropic Claude, OpenRouter, Hugging Face, Ollama và OpenCode) thông qua kiến trúc Adapter thống nhất:

1. **Quản lý khóa API 3 tầng (BYOK Vault)**: Hệ thống cho phép cấu hình khóa API theo thứ tự ưu tiên từ khóa riêng của Workspace, khóa cá nhân của người dùng đến biến môi trường hệ thống (`AI_API_KEY`). Các khóa do người dùng nhập được mã hóa đối xứng bằng thuật toán Fernet (kết hợp dẫn xuất khóa PBKDF2) và chỉ hiển thị dạng che dấu (`masked_key`) trên giao diện.
2. **Kiểm soát ngữ cảnh và Prompt tách rời mã nguồn**: Chỉ dẫn prompt được lưu trữ độc lập tại `backend/prompts/prompts.json` theo 3 phiên bản (`v1`, `v2`, `v3`). Trước khi gửi yêu cầu tới mô hình, hệ thống chỉ trích xuất thông tin nghiệp vụ cần thiết (tên sản phẩm, USP, mục tiêu, kênh, từ khóa cấm trong Brand Kit) và loại bỏ hoàn toàn mật khẩu, khóa bí mật hay dữ liệu ngoài phạm vi quyền hạn.
3. **Cơ chế dự phòng có gắn nhãn (Smart Fallback)**: Khi gặp sự cố mạng, quá thời gian chờ hoặc phản hồi sai định dạng JSON Schema, hệ thống chuyển sang bộ mẫu dự phòng xác định, đồng thời gắn cờ `is_fallback = True` và hiển thị cảnh báo rõ ràng trên giao diện để người dùng không nhầm lẫn với kết quả do mô hình AI sinh ra.

2.2.4. Cơ sở dữ liệu: SQLite với WAL Mode và SQLAlchemy 2.0

Hệ thống sử dụng SQLite làm hệ quản trị cơ sở dữ liệu hạt nhân trong giai đoạn vận hành hiện tại với các cấu hình tối ưu hóa chuyên sâu:

1. **Ràng buộc khóa ngoại bắt buộc**: Mặc định SQLite không bật kiểm tra khóa ngoại; hệ thống kích hoạt tường minh chỉ thị `PRAGMA foreign_keys = ON` ngay khi khởi tạo mỗi session kết nối trong `backend/app/db/session.py`, bảo đảm tính toàn vẹn tham chiếu 100%.
2. **Chế độ Write-Ahead Logging (WAL)**: Bật `PRAGMA journal_mode = WAL` cho phép các tiến trình đọc (readers) và tiến trình ghi (writer) hoạt động đồng thời mà không gây khóa bảng (table lock), gia tăng thông lượng xử lý của hệ thống.
3. **Chuyển đổi linh hoạt qua SQLAlchemy 2.0**: Việc sử dụng chuẩn SQLAlchemy 2.0 Declarative Base giúp toàn bộ định nghĩa bảng, chỉ mục (indices) và ràng buộc duy nhất (UniqueConstraints) hoàn toàn độc lập với phần mềm máy chủ CSDL, sẵn sàng chuyển đổi liền mạch sang PostgreSQL trong môi trường sản xuất quy mô lớn.

2.2.5. Đóng gói Container và Tự động hóa CI/CD

1. **Kiến trúc Containerization**: Ứng dụng được đóng gói thành các dịch vụ độc lập trong `docker-compose.yml`: dịch vụ Backend chạy trên nền Python 3.11-slim tối giản dung lượng theo chuẩn Non-Root, và dịch vụ Frontend sử dụng kỹ thuật multi-stage build (biên dịch bằng Node.js và phân phối tĩnh bằng máy chủ web siêu nhẹ Nginx Alpine).
2. **Tự động hóa tích hợp liên tục (CI Pipeline)**: Pipeline GitHub Actions (`.github/workflows/ci.yml`) tự động kích hoạt mỗi khi có mã nguồn mới, thực hiện toàn diện ba giai đoạn: kiểm tra chất lượng mã (Linting/Typecheck), chạy bộ test tự động backend với `pytest`, và kiểm tra tính toàn vẹn khi đóng gói container Docker.
3. **Giám sát sức khỏe tự động (Health Check Lifecycle)**: Cài đặt endpoint `GET /health` trả về trạng thái kết nối CSDL, tính sẵn sàng của Gemini API và tình trạng phân bổ bộ nhớ; tích hợp trực tiếp vào Docker daemon để hỗ trợ cơ chế tự phục hồi dịch vụ (Self-healing).

2.3. Kết luận chương

Việc lựa chọn và kết hợp hài hòa giữa FastAPI, React 18, hệ sinh thái mô hình Google Gemini, SQLite tối ưu hóa sâu (WAL mode) và container hóa Docker đã tạo nên một nền tảng kỹ thuật vững chắc cho MarketFlow AI. Sự nhất quán về công nghệ và việc tuân thủ triệt để các tiêu chuẩn kỹ thuật quốc tế là tiền đề để triển khai chi tiết các yêu cầu nghiệp vụ phức tạp ở các chương tiếp theo.

Nền tảng kiến trúc này vừa bảo đảm tính linh hoạt cao trong quá trình phát triển nhanh, vừa đặt nền móng vững chắc cho khả năng mở rộng quy mô tải và chuyển đổi liền mạch sang môi trường máy chủ phân tán trong tương lai.

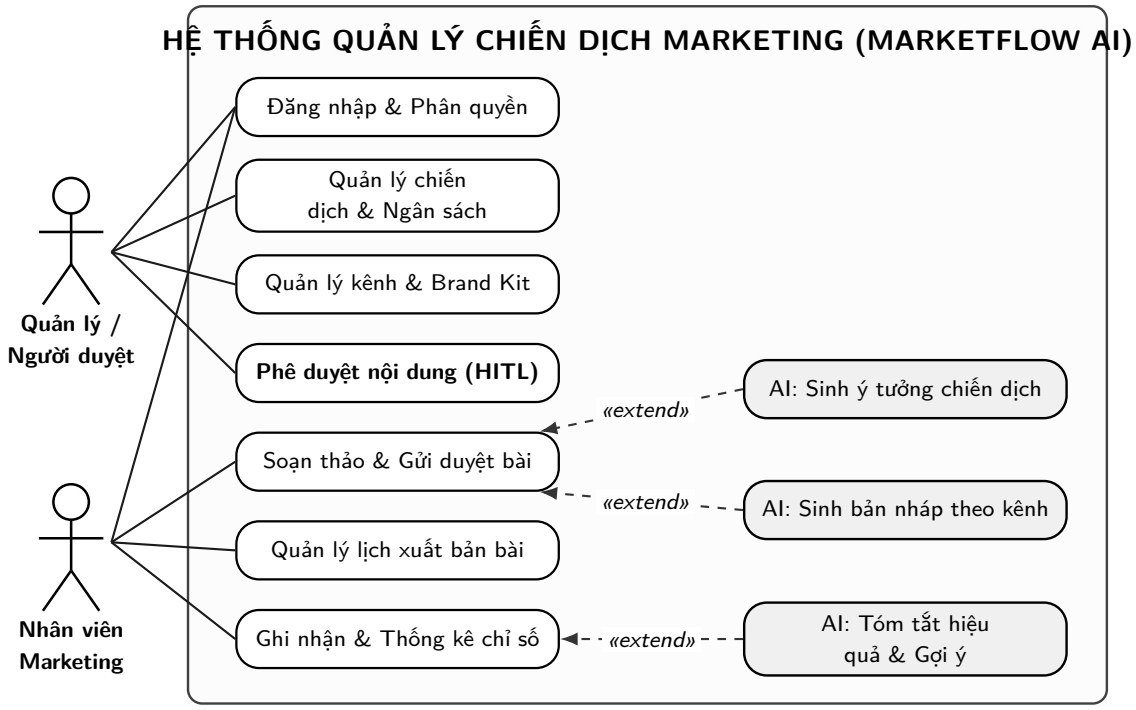
CHƯƠNG 3.
PHÂN TÍCH YÊU CẦU HỆ THỐNG VÀ KIỂM SOÁT PHÂN QUYỀN

3.1. Phân tích tác nhân và mục tiêu nghiệp vụ

Hệ thống MarketFlow AI được thiết kế xoay quanh hai nhóm tác nhân con người chính (Manager và Marketer) cùng hai thực thể ngoại vi (Nhà cung cấp dịch vụ AI và Nền tảng phân phối nội dung), được định nghĩa trong Bảng 3.1.

Bảng 3.1: *Tác nhân, mục tiêu và ranh giới quyền hạn trong hệ thống*

Tác nhân	Mục tiêu nghiệp vụ	Ranh giới quyền hạn
Quản lý Marketing (Manager)	Thiết lập chiến dịch, duyệt ngân sách, phân công thành viên, thẩm định và phê duyệt nội dung, xem báo cáo tổng thể toàn doanh nghiệp.	Quyền quản trị toàn hệ thống; có quyền duyệt/từ chối (`/approve`, `/reject`); không được can thiệp sửa đổi nhật ký kiểm toán bất biến.
Nhân viên Marketing (Marketer)	Sáng tạo ý tưởng, gọi AI trợ lý soạn thảo bản nháp, biên tập nội dung, gửi yêu cầu duyệt, nhập số liệu chiến dịch được giao.	Chỉ thao tác trong phạm vi các chiến dịch được phân công (Record-level Scope); tuyệt đối không có quyền tự phê duyệt bài viết của chính mình.
Dịch vụ Google Gemini AI	Nhận ngữ cảnh dữ liệu chọn lọc, sinh gợi ý ý tưởng, soạn nháp và tóm tắt chỉ số theo JSON Schema quy chuẩn.	Thực thể tính toán thụ động; không có quyền truy cập trực tiếp CSDL; kết quả luôn mang tính khuyến nghị và gắn cờ `is_ai_generated = True`.
Kênh truyền thông	Tiếp nhận lịch đăng và nội dung đã được phê duyệt chính thức để chuẩn bị xuất bản.	Đứng sau rào chắn kiểm duyệt; chỉ tiếp nhận nội dung có trạng thái `APPROVED` và lịch biểu hợp lệ.



Hình 3.1: *Sơ đồ ca sử dụng chính của hệ thống MarketFlow AI*

3.2. Danh mục yêu cầu chức năng (FR)

Hệ thống hiện thực hóa trọn vẹn 14 yêu cầu chức năng cốt lõi (FR01–FR14), toàn bộ đều đã được kiểm chứng bằng các ca kiểm thử tự động, như được chi tiết hóa trong Bảng 3.2.

Bảng 3.2: *Danh mục yêu cầu chức năng và kết quả nghiệm thu thực chứng*

Mã	Phân hệ	Nội dung yêu cầu	Kết quả kiểm chứng thực tế	Trạng thái
FR01	Xác thực	Đăng nhập bằng email và mật khẩu; cấp phát JWT token an toàn.	Đăng nhập thành công cấp Bearer token; sai mật khẩu trả 401 Unauthorized; mã hóa Bcrypt.	TESTED
FR02	Phân quyền	Backend kiểm tra vai trò ở các thao tác nhạy cảm.	Manager được duyệt bài/xóa chiến dịch; Marketer bị từ chối 403 Forbidden; tài khoản bị khóa bị chặn ngay lập tức.	TESTED
FR03	Dữ liệu nền	Quản lý danh mục ngành hàng, sản phẩm và kênh tiếp thị.	Đầy đủ CRUD; ràng buộc khóa ngoại ngăn chặn xóa danh mục khi còn sản phẩm tham chiếu.	IMPLEMENTED

Mã	Phân hệ	Nội dung yêu cầu	Kết quả kiểm chứng thực tế	Trạng thái
FR04	Chiến dịch	Tạo và quản lý chiến dịch với mục tiêu, ngân sách, thời gian.	Kiểm tra ngân sách không âm; ràng buộc ngày `start_date` ≤ `end_date`; chống SQL injection.	TESTED
FR05	Phân công	Quản lý thành viên tham gia chiến dịch (`CampaignMember`).	Hỗ trợ phân công nhiều thành viên vào chiến dịch; ngăn chặn trùng lặp thành viên; xác lập phạm vi quyền.	TESTED
FR06	Soạn nội dung	Tạo bản nháp nội dung gắn với chiến dịch, kênh và tác giả.	Nội dung khởi tạo mang trạng thái `DRAFT` hoặc `AI_DRAFT`; kiểm tra khóa ngoại chiến dịch/kênh.	TESTED
FR07	Duyệt nội dung	Quy trình phê duyệt Human-in-the-loop qua các endpoint chuyên biệt.	Gửi duyệt (`/submit`), phê duyệt (`/approve`), từ chối (`/reject`); cấm tự duyệt; tự động reset khi sửa.	TESTED
FR08	Lập lịch	Tạo, sửa và hủy lịch xuất bản cho nội dung đã duyệt.	Chỉ cho phép lên lịch đối với bài viết `APPROVED`; hỗ trợ múi giờ quốc tế; trạng thái đồng bộ `SCHEDULED`.	TESTED
FR09	Chỉ số kênh	Nhập views, clicks, conversions, cost và revenue theo ngày/kênh.	Bộ ba (`campaign`, `channel`, `date`) duy nhất; tự động tính toán KPI: CTR, CPC, CPA, ROI; chống chia cho 0.	TESTED
FR10	Báo cáo	Lọc, tìm kiếm chiến dịch và xem dashboard số liệu đa chiều.	Lọc đa tiêu chí theo kênh, thời gian; tổng hợp số liệu chính xác; Marketer chỉ xem số liệu chiến dịch của mình.	TESTED
FR11	AI Ý tưởng	Gợi ý 3 góc tiếp cận ý tưởng dựa trên mục tiêu và sản phẩm.	Trả về cấu trúc JSON gồm angle, concept, hook; schema valid 100%; Smart Fallback kích hoạt khi mất mạng.	MEASURED

Mã	Phân hệ	Nội dung yêu cầu	Kết quả kiểm chứng thực tế	Trạng thái
FR12	AI Soạn nháp	Tạo caption/email theo định dạng chuẩn của từng kênh.	Sinh tiêu đề, nội dung, lời kêu gọi (CTA); gắn cờ nguồn gốc AI; chuyển tiếp mượt mà sang Review Queue.	MEASURED
FR13	AI Tóm tắt	Tóm tắt hiệu quả và khuyến nghị cải tiến từ metrics thực tế.	Grounding score >95%; khử ảo giác tuyệt đối trong Fallback (chỉ diễn giải số liệu có trong context).	MEASURED
FR14	Kiểm toán	Ghi nhận audit log cho các thao tác duyệt và lần gọi AI.	Bảng `content_reviews` lưu lý do duyệt; bảng `ai_logs` lưu chi tiết model, latency, tokens và cờ fallback.	TESTED

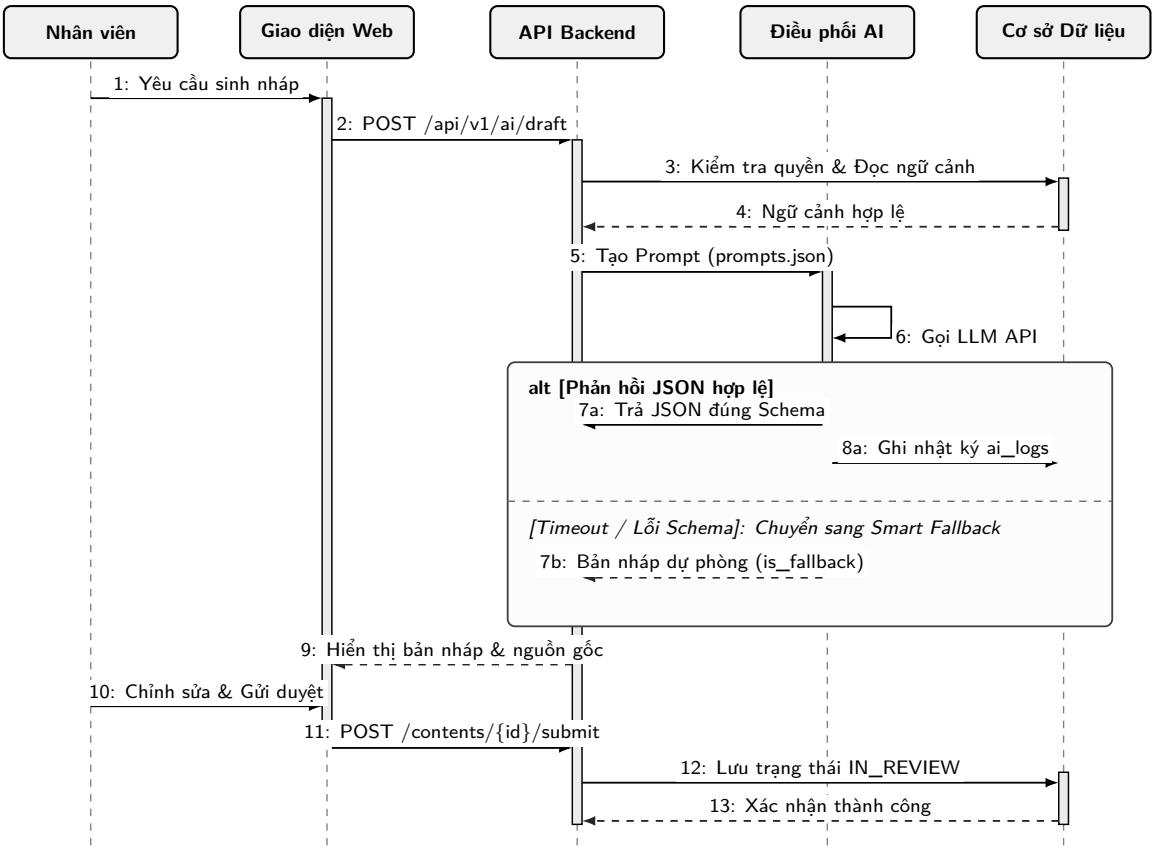
3.3. Danh mục yêu cầu chất lượng (NFR)

Hệ thống tuân thủ 6 yêu cầu phi chức năng (NFR01–NFR06) đạt tiêu chuẩn công nghiệp:

- **NFR01 (Kiểm soát truy cập đa tầng)**: Kết hợp RBAC và kiểm soát phạm vi bản ghi (Record-level Scope). Loại bỏ hoàn toàn nguy cơ rò rỉ dữ liệu chéo giữa các nhân viên tiếp thị.
- **NFR02 (Toàn vẹn dữ liệu và giao dịch)**: SQLite kích hoạt `PRAGMA foreign_keys = ON`, ràng buộc chỉ số không âm, bảo toàn tính nguyên tử (Atomicity) qua SQLAlchemy transactions.
- **NFR03 (Hiệu năng phản hồi)**: Thời gian phản hồi của các API nghiệp vụ CRUD đạt P50 $<$ 15ms, P95 $<$ 45ms. Độ trễ AI Smart Fallback $<$ 50ms.
- **NFR04 (Tính khả dụng và phục hồi giao diện)**: Giao diện web hỗ trợ đầy đủ ba trạng thái tương tác: loading skeleton, empty state thông minh, và toast thông báo tức thời.
- **NFR05 (Khả năng chịu lỗi dịch vụ AI)**: Tự động bắt lỗi timeout (sau 10 giây), lỗi quota hoặc lỗi sai lệch JSON Schema từ nhà cung cấp mô hình để chuyển hướng an toàn sang Smart Fallback mà không gây gián đoạn phiên làm việc của người dùng.
- **NFR06 (Khả năng tái lập và tự động hóa)**: Cung cấp đầy đủ cấu hình Docker, script khởi tạo seed dữ liệu mẫu và pipeline GitHub Actions xác minh toàn diện mọi thay đổi.

3.4. Kiến trúc phân quyền RBAC và Kiểm soát mức bản ghi (Record-level NFR01)

Một trong những cải tiến quan trọng nhất trong kiến trúc an ninh của MarketFlow AI V9 là việc siết chặt phân quyền mức bản ghi (Record-level Authorization), khắc phục hoàn toàn lỗ hổng IDOR (Insecure Direct Object Reference).



Hình 3.2: *Quy trình phân quyền và kiểm soát phạm vi bản ghi khi xử lý yêu cầu*

3.4.1. Cơ chế đồng bộ trạng thái tài khoản người dùng

Trong module xác thực `backend/app/core/security.py` và `backend/app/api/deps.py`, hàm phụ thuộc `get_current_user` và lớp `RoleChecker` không chỉ kiểm tra tính hợp lệ của chữ ký điện tử JWT mà còn bắt buộc truy vấn trạng thái thực của người dùng trong cơ sở dữ liệu:

$$\text{Allowed} \iff (\text{Token Valid}) \land (\text{User.status} == \text{'ACTIVE'}) \land (\text{Role} \in \text{AllowedRoles}) \tag{3.1}$$

Nếu tài khoản bị vô hiệu hóa (`user.status == 'INACTIVE'`), hệ thống lập tức từ chối yêu cầu với mã lỗi HTTP 403 Forbidden, bất kể token JWT vẫn còn trong thời hạn hiệu lực.

3.4.2. Thuật toán giải quyết phạm vi bản ghi (Record Scope Resolution)

Đối với vai trò Marketer, quyền thao tác trên các thực thể được xác định nghiêm ngặt theo thuật toán sau:

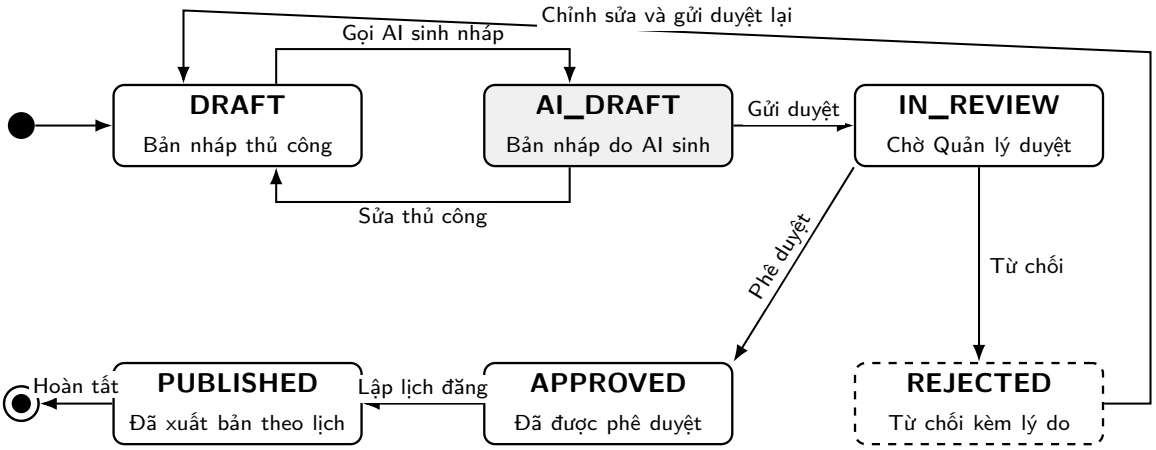
1. **Đối với Chiến dịch (Campaign)**:
    - Manager: Có quyền xem, tạo, chỉnh sửa và xóa mọi chiến dịch trong hệ thống.
    - Marketer: Chỉ được xem và cập nhật các chiến dịch mà mình là người tạo lập (`campaign.owner_id == current_user.id`) hoặc được chỉ định là thành viên thông qua bảng liên kết `CampaignMember` (`campaign_members.user_id == current_user.id`). Mọi yêu cầu truy cập chiến dịch ngoài phạm vi đều bị chặn

với HTTP 403 hoặc HTTP 404 (để che giấu sự tồn tại của tài nguyên). Thao tác xóa chiến dịch bị cấm hoàn toàn đối với Marketer.

2. **Đối với Nội dung tiếp thị (MarketingContent)**:
   - Marketer chỉ được tạo bài viết mới gắn với chiến dịch mà mình có quyền phụ trách.
   - Khi xem danh sách hoặc chỉnh sửa nội dung, backend tự động lọc hoặc kiểm tra quan hệ sở hữu của chiến dịch chứa nội dung đó. Marketer không thể đọc hay can thiệp vào bài viết thuộc chiến dịch của đồng nghiệp khác.
3. **Đối với Chỉ số hiệu quả (Metrics) và Bảng điều khiển (Dashboard)**:
   - Khi Marketer truy cập `GET /metrics/dashboard`, hệ thống tự động chèn mệnh đề lọc `campaign_id.in_(allowed_campaign_ids)`, bảo đảm người dùng chỉ nhìn thấy số liệu tổng hợp trong phạm vi được phân công.
4. **Đối với Ngữ cảnh AI (AI Context Gate)**:
   - Khi gọi các endpoint AI (`/ai/ideas`, `/ai/draft`, `/ai/summary`), hệ thống kiểm tra quyền của Marketer trên `campaign_id` mục tiêu trước khi nạp dữ liệu vào Prompt Engine, triệt tiêu nguy cơ trích xuất thông tin chiến dịch của người khác qua AI.

3.5. Máy trạng thái duyệt nội dung Human-in-the-loop (HITL State Machine)

Để bảo đảm tính toàn vẹn của nội dung truyền thông doanh nghiệp, vòng đời của mỗi bài viết tiếp thị tuân thủ một máy trạng thái hữu hạn (Finite State Machine) nghiêm ngặt được mô tả tại Hình 3.3.



Hình 3.3: *Máy trạng thái duyệt nội dung Human-in-the-loop*

3.5.1. Các trạng thái hợp lệ

- `DRAFT`: Bản nháp do người dùng tự soạn thảo thủ công.
- `AI_DRAFT`: Bản nháp do AI sinh ra, cần sự rà soát chỉnh sửa của con người.
- `IN_REVIEW`: Bài viết đã được hoàn thiện và gửi lên hàng đợi phê duyệt (Review Queue).
- `APPROVED`: Bài viết đã được cấp quản lý (Manager) thẩm định và chính thức phê duyệt.

- `REJECTED`: Bài viết bị từ chối phê duyệt (kèm lý do giải thích minh bạch).
- `PUBLISHED`: Bài viết đã được phát hành lên kênh truyền thông theo lịch đăng.

3.5.2. Quy tắc chống gian lận và can thiệp ngoài luồng (Anti-Tampering Rules)

Nhằm triệt tiêu hoàn toàn khả năng người dùng vượt quyền hoặc bỏ qua khâu kiểm duyệt, hệ thống áp dụng các rào chắn kỹ thuật ở tầng sâu:

1. **Cấm tạo bài viết trực tiếp ở trạng thái duyệt**: Endpoint `POST /contents` tuyệt đối không chấp nhận tham số trạng thái `APPROVED` hoặc `PUBLISHED`. Mọi nội dung tạo mới chỉ có thể bắt đầu ở `DRAFT` hoặc `AI_DRAFT`.
2. **Cấm sửa đổi trực tiếp trạng thái qua API cập nhật**: Endpoint `PUT /contents/{id}` từ chối mọi nỗ lực gán trường `status` sang `APPROVED` hoặc `PUBLISHED` với mã lỗi HTTP 400 Bad Request.
3. **Endpoint nghiệp vụ chuyên biệt**: Việc thay đổi trạng thái bắt buộc phải thông qua các endpoint chuyên trách:
    - `POST /contents/{id}/submit`: Chuyển từ `DRAFT` / `AI_DRAFT` / `REJECTED` sang `IN_REVIEW` (bất kỳ tác giả nào có quyền trên nội dung đều gọi được).
    - `POST /contents/{id}/approve`: Chỉ cho phép vai trò Manager gọi trên các bài viết đang ở `IN_REVIEW`. Tự động ghi nhận thông tin người duyệt và mốc thời gian vào bảng kiểm toán.
    - `POST /contents/{id}/reject`: Chỉ cho phép vai trò Manager gọi trên các bài viết đang ở `IN_REVIEW`, bắt buộc truyền tham số lý do (`review_notes`).
    - `POST /contents/{id}/publish`: Chỉ cho phép xuất bản bài viết đang ở trạng thái `APPROVED`.
4. **Cơ chế tự động thu hồi phê duyệt khi nội dung bị sửa đổi (Approval Invalidation)**: Nếu một bài viết đã ở trạng thái `APPROVED` nhưng sau đó bị người dùng chỉnh sửa tiêu đề (`title`), nội dung (`body`) hoặc lời kêu gọi (`cta`) qua `PUT /contents/{id}`, hệ thống tự động hạ trạng thái bài viết về `AI_DRAFT` và yêu cầu phải trải qua toàn bộ quy trình gửi duyệt lại từ đầu. Quy tắc này loại bỏ hoàn toàn kịch bản gian lận: phê duyệt một nội dung lành tính rồi sau đó bí mật thay đổi thành nội dung vi phạm chính sách.

3.6. Kết luận chương

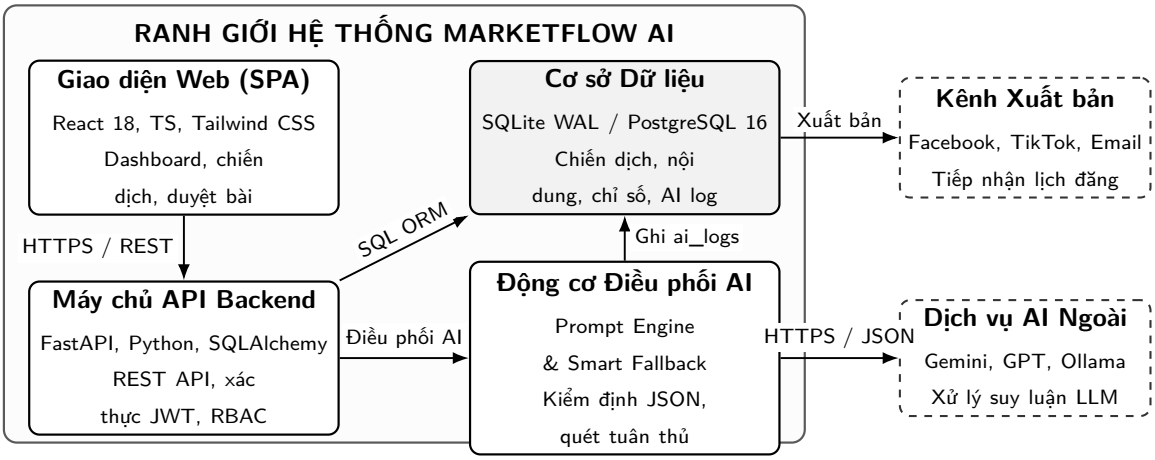
Chương 3 đã hoàn thiện phân tích chi tiết toàn bộ các yêu cầu nghiệp vụ của MarketFlow AI. Sự kết hợp chặt chẽ giữa Ma trận phân quyền RBAC, cơ chế kiểm soát phạm vi bản ghi (Record-level Scope NFR01) và Máy trạng thái duyệt nội dung khép kín (HITL State Machine) đã thiết lập nên một kiến trúc bảo mật đa tầng, ngăn chặn mọi hành vi leo quyền hoặc can thiệp dữ liệu trái phép. Chương tiếp theo sẽ trình bày thiết kế kiến trúc tổng thể, mô hình dữ liệu và Prompt Engine của hệ thống.

CHƯƠNG 4.
THIẾT KẾ KIẾN TRÚC VÀ MÔ HÌNH DỮ LIỆU

4.1. Quan điểm thiết kế kiến trúc tổng thể

Kiến trúc hệ thống MarketFlow AI được thiết kế theo mô hình phân tầng hướng dịch vụ (Layered Service-Oriented Architecture), kết hợp các nguyên lý Clean Architecture và Domain-Driven Design (DDD). Việc tách bạch rõ ràng giữa tầng Giao diện (Presentation Layer), tầng Điều hướng API (API Routing Layer), tầng Nghiệp vụ cốt lõi (Domain Service Layer), tầng Truy xuất dữ liệu (Data Access Layer) và tầng Tích hợp ngoại vi (AI Integration Adapter) bảo đảm hệ thống có tính mở cao, dễ bảo trì và có thể kiểm thử độc lập từng thành phần.

Hệ thống được mô hình hóa theo chuẩn C4 Container tại Hình 4.1.



Hình 4.1: *Sơ đồ kiến trúc Container và luồng dữ liệu hệ thống*

4.2. Các khối thành phần và phân định trách nhiệm

Máy chủ ứng dụng FastAPI được cấu trúc thành các module chức năng độc lập trong thư mục `backend/app/api/v1/`, mỗi module chịu trách nhiệm thực thi một ranh giới nghiệp vụ cụ thể được mô tả trong Bảng 4.1.

Bảng 4.1: *Phân định trách nhiệm của các module trong hệ thống*

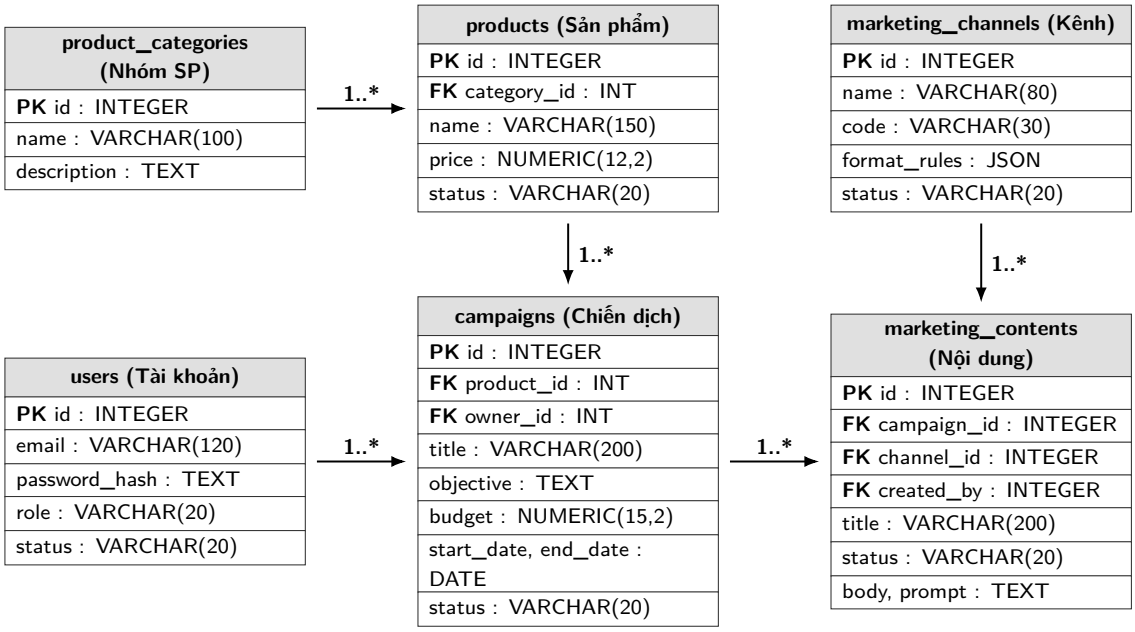
Module backend	Trách nhiệm kỹ thuật và nghiệp vụ	Yêu cầu đáp ứng
`auth.py` & `security.py`	Quản lý phiên xác thực JWT, băm mật khẩu bằng thuật toán Bcrypt, kiểm tra trạng thái kích hoạt tài khoản (`user.status == 'ACTIVE'`) và phân quyền vai trò.	FR01, FR02, NFR01
`campaigns.py`	Xử lý vòng đời chiến dịch; xác thực khoảng thời gian (`start_date` $\leq$ `end_date`); kiểm tra ngân sách hợp lệ; kiểm soát phân quyền mức bản ghi theo `owner_id` và `CampaignMember`.	FR04, FR05, NFR01
`contents.py`	Quản lý máy trạng thái nội dung HITL; cấm tạo/sửa trực tiếp trạng thái duyệt; điều phối quy trình gửi duyệt (`/submit`), phê duyệt (`/approve`), từ chối (`/reject`) và xuất bản (`/publish`); tự động hạ cấp về `AI_DRAFT` khi nội dung đã duyệt bị sửa đổi.	FR06, FR07, FR14
`schedules.py`	Quản lý lịch phát hành bài viết; kiểm tra điều kiện tiên quyết (chỉ lập lịch cho nội dung `APPROVED`); xử lý múi giờ quốc tế; ngăn ngừa xung đột thời gian phát hành.	FR08, NFR02
`metrics.py`	Quản lý chỉ số hiệu quả đa kênh theo bộ ba duy nhất (`campaign`, `channel`, `date`); tính toán tự động các chỉ số tài chính (CTR, CPC, CPA, ROI) với cơ chế bảo vệ chia cho 0; tổng hợp dữ liệu bảng điều khiển (Dashboard) phân quyền theo người dùng.	FR09, FR10, NFR03
`ai.py` & `ai_service.py`	Cổng giao tiếp AI đa tác vụ; kiểm soát phạm vi truy cập dữ liệu trước khi sinh prompt; điều phối gọi Google Gemini API; tự động kích hoạt Smart Fallback khi gặp sự cố; lưu trữ nhật ký kiểm toán vào `ai_logs`.	FR11–FR14, NFR05

4.3. Thiết kế mô hình dữ liệu quan hệ (ERD)

Mô hình dữ liệu được thiết kế tuân thủ dạng chuẩn 3 (3NF), bảo đảm tính toàn vẹn dữ liệu, tối ưu hóa tốc độ truy vấn và loại bỏ hiện tượng dư thừa thông tin.

4.3.1. Mô hình dữ liệu hạt nhân (Core ERD)

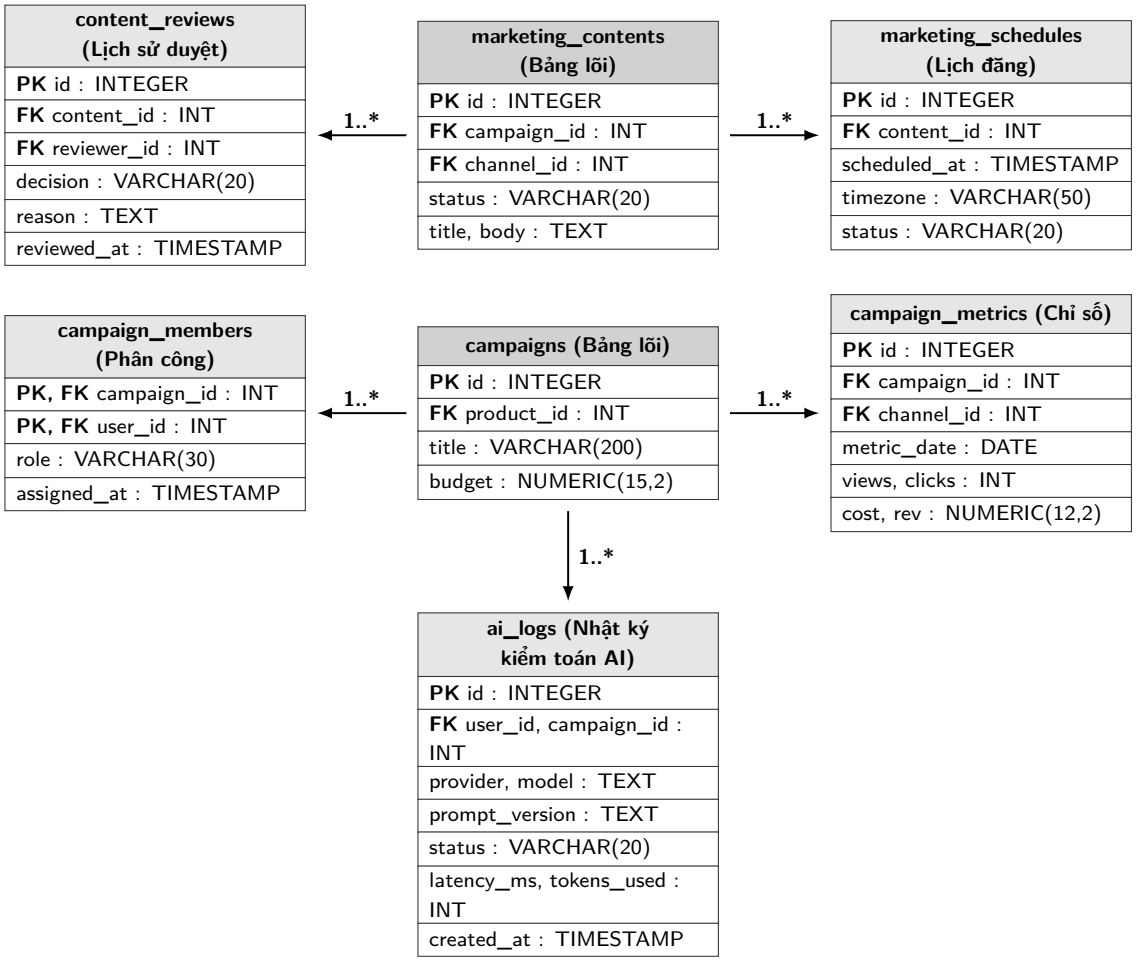
Hình 4.2 thể hiện các thực thể nghiệp vụ trung tâm và các mối quan hệ quan trọng.



Hình 4.2: *Mô hình dữ liệu hạt nhân của MarketFlow AI*

4.3.2. Mô hình các bảng vận hành và nhật ký kiểm toán (Operations ERD)

Hình 4.3 thể hiện các bảng phụ trợ phục vụ quy trình phân công, phê duyệt, lập lịch, số liệu hiệu quả và kiểm toán AI.



Hình 4.3: *Mô hình các bảng vận hành và liên kết khóa ngoại*

4.3.3. Từ điển dữ liệu và các ràng buộc toàn vẹn

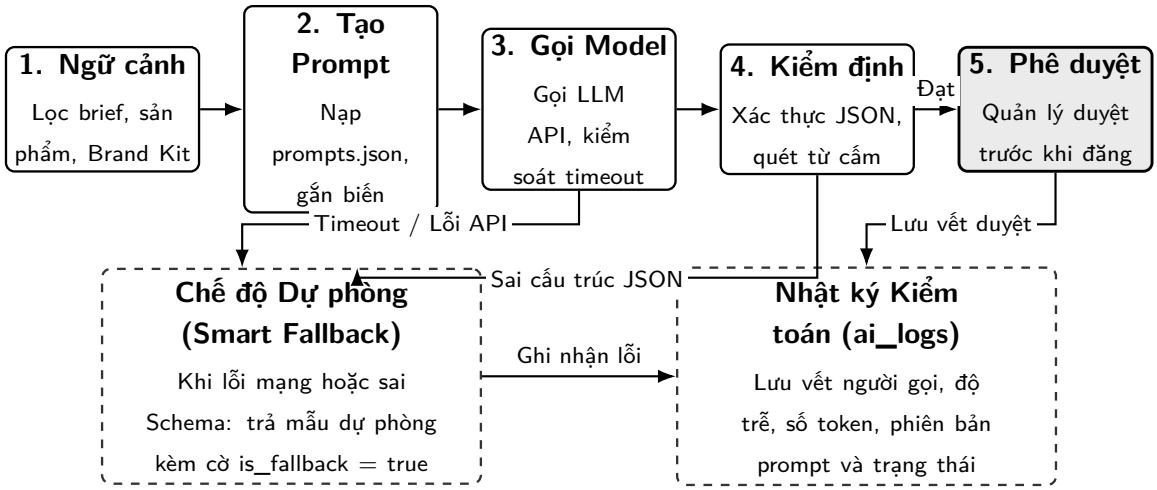
Bảng 4.2 đặc tả chi tiết cấu trúc các bảng dữ liệu, khóa chính, khóa ngoại và ràng buộc toàn vẹn đã được hiện thực hóa trong SQLite và SQLAlchemy.

Bảng 4.2: *Từ điển dữ liệu và các ràng buộc toàn vẹn*

Tên bảng	Mục đích	Cơ chế khóa	Ràng buộc và quy tắc nghiệp vụ
`users`	Quản lý tài khoản	PK: `id`	`email` duy nhất (Unique); `role` thuộc {MANAGER, MARKETER}; `status` thuộc {ACTIVE, INACTIVE}; mật khẩu lưu dạng hash Bcrypt.
`product_categories`	Danh mục ngành hàng	PK: `id`	`name` duy nhất; bảo vệ toàn vẹn danh mục.
`products`	Sản phẩm	PK: `id`; FK: `category_id`	Khóa ngoại liên kết danh mục; giá tiền không âm (`price` ≥ 0).
`marketing_channels`	Kênh truyền thông	PK: `id`	`code` duy nhất thuộc {FACEBOOK, EMAIL, GOOGLE_ADS, TIKTOK}.
`campaigns`	Chiến dịch tiếp thị	PK: `id`; FK: `product_id`, `owner_id`	`budget` ≥ 0; `start_date` $\leq$ `end_date`; xóa cascade các nội dung và chỉ số liên quan.
`campaign_members`	Phân công nhân sự	PK kép: (`campaign_id`, `user_id`)	Khóa chính phức hợp ngăn ngừa gán trùng lặp một nhân viên vào cùng chiến dịch.
`marketing_contents`	Nội dung truyền thông	PK: `id`; FK: `campaign_id`, `channel_id`, `creator_id`	`status` tuân thủ máy trạng thái; cờ `is_ai_generated` xác định nguồn gốc.
`content_reviews`	Nhật ký kiểm duyệt	PK: `id`; FK: `content_id`, `reviewer_id`	Ghi nhận quyết định (APPROVED/REJECTED), lý do duyệt và mốc thời gian bất biến.
`marketing_schedules`	Lịch xuất bản	PK: `id`; FK: `content_id`	Chỉ tạo cho nội dung `APPROVED`; lưu trữ múi giờ quốc tế (`timezone`).
`campaign_metrics`	Chỉ số định lượng kênh	PK: `id`; FK: `campaign_id`, `channel_id`	Ràng buộc Unique phức hợp (`campaign_id`, `channel_id`, `metric_date`); các chỉ số views, clicks, conversions, cost, revenue không âm.
`ai_logs`	Nhật ký kiểm toán AI	PK: `id`; FK: `user_id`	Ghi nhận `task_type`, `model_provider`, `model_name`, `latency_ms`, `status`, cờ `is_fallback`.

4.4. Thiết kế Prompt Engine và Kiểm soát ngữ cảnh an toàn

Luồng tương tác với mô hình trí tuệ nhân tạo được quản lý tập trung thông qua Động cơ Xây dựng Chỉ dẫn (Prompt Engine) và Dịch vụ Điều phối Trí tuệ Nhân tạo (AI Service) theo quy trình khép kín tại Hình 4.4.



Hình 4.4: *Quy trình xử lý yêu cầu AI với Prompt Engine và Smart Fallback*

4.4.1. Nguyên tắc lọc sạch ngữ cảnh (Context Whitelisting)

Để tuân thủ tiêu chuẩn an toàn dữ liệu, hệ thống áp dụng kỹ thuật Whitelisting nghiêm ngặt:

- **Dữ liệu cho phép đưa vào Prompt**: Tên sản phẩm, mô tả tính năng, mục tiêu chiến dịch, đối tượng khách hàng mục tiêu, giọng văn (tone of voice), và mảng dữ liệu chỉ số chiến dịch đã được lọc theo quyền của người dùng.
- **Dữ liệu tuyệt đối cấm đưa vào Prompt**: Thông tin nhận dạng cá nhân (PII), mật khẩu, token JWT, mã băm, khóa API, số dư tài khoản ngân hàng hoặc dữ liệu của các chiến dịch khác ngoài phạm vi được phân công.

4.4.2. Đặc tả hợp đồng dữ liệu chuẩn hóa (Data Contract Specification)

Toàn bộ mẫu prompt được tách khỏi mã nguồn Python và quản lý tại `backend/prompts/prompts.json` với 3 phiên bản (`v1`, `v2`, `v3`). Prompt Engine thiết lập hợp đồng dữ liệu đầu ra qua Pydantic v2 nhằm kiểm tra cấu trúc JSON trước khi chuyển sang tầng ứng dụng (Bảng 4.3).

Bảng 4.3: *Đặc tả hợp đồng dữ liệu Pydantic Schema cho các tác vụ AI*

Tác vụ	Trường dữ liệu	Kiểu dữ liệu	Ý nghĩa nghiệp vụ & Ràng buộc
IDEA	`campaign_name`	`str`	Tên chiến dịch ngữ cảnh mục tiêu.
	`ideas`	`List[IdeaItem]`	Danh sách đúng 5 góc tiếp cận ý tưởng.
	`ideas[i]`	`Dict[str, str]`	Gồm 3 khóa: `angle`, `concept`, `target_hook`.
DRAFT	`channel`	`ChannelEnum`	Kênh truyền thông mục tiêu (Facebook, TikTok, Email).
	`title, body`	`str`	Tiêu đề và thân bài viết theo giới hạn ký tự kênh.
	`cta`	`str`	Lời kêu gọi hành động cụ thể (`CTA`).
SUMMARY	`kpi_overview`	`Dict[str, float]`	Tổng hợp số học: views, clicks, cost, revenue, ROI.
	`insights, recs`	`List[str]`	Nhận định bám sát số liệu đã lưu và đề xuất cải thiện.

4.4.3. Cơ chế dự phòng xác định (Smart Fallback)

Khi gặp sự cố kết nối LLM hoặc quá thời gian chờ, hệ thống kích hoạt hàm `_generate_fallback`: (1) Ý tưởng và bản nháp được tạo theo khung mẫu gắn với sản phẩm và kênh đã chọn; (2) Tóm tắt chỉ số tính toán trực tiếp từ mảng metrics hiện có, không suy diễn ngoài dữ liệu; (3) Gắn cờ `is_fallback = True`, ghi vào `ai_logs` và hiển thị cảnh báo rõ trên giao diện.

4.5. Kết luận chương

Chương 4 đã trình bày thiết kế kiến trúc phân tầng, mô hình dữ liệu quan hệ và cơ chế tương tác với mô hình ngôn ngữ lớn qua Prompt Engine, làm cơ sở cho việc hiện thực hóa ở Chương 5.

CHƯƠNG 5.
HIỆN THỰC HÓA HỆ THỐNG

5.1. Tổng quan cấu trúc mã nguồn thực tế

Toàn bộ hệ thống MarketFlow AI đã được hiện thực hóa hoàn chỉnh bằng mã nguồn thực tế trong hai thư mục chính: `backend/` và `frontend/`. Bảng 5.1 mô tả cấu trúc phân bổ mã nguồn của dự án.

Bảng 5.1: *Cấu trúc phân bổ mã nguồn hệ thống MarketFlow AI*

Đường dẫn thư mục	Mô tả thành phần mã nguồn	Công nghệ sử dụng
`backend/app/core`	Cấu hình môi trường (`config.py`) và bảo mật (`security.py`: Bcrypt, JWT, RoleChecker).	Python 3.11, Passlib, PyJWT
`backend/app/db`	Khởi tạo session CSDL (`session.py`) và Base ORM (`base.py`), script nạp dữ liệu mẫu (`init_db.py`).	SQLAlchemy 2.0, SQLite WAL
`backend/app/models`	Định nghĩa 11 thực thể dữ liệu quan hệ (User, Campaign, Content, Metric, Schedule, Product, Channel, AILog, v.v.).	SQLAlchemy 2.0 Declarative
`backend/app/schemas`	Định nghĩa hợp đồng dữ liệu vào/ra với các bộ kiểm định hợp lệ (Validation).	Pydantic v2
`backend/app/api/v1`	Bộ điều phối API endpoints: xác thực, quản lý chiến dịch, duyệt nội dung, lập lịch, số liệu, AI.	FastAPI Routers
`backend/app/services`	Động cơ điều phối AI (`ai_service.py`) và xây dựng prompt an toàn (`prompt_engine.py`).	Google Gemini SDK, Fallback Engine
`backend/tests`	Toàn bộ bộ kiểm thử tự động: unit tests, integration tests, fuzzing, adversarial security tests.	Pytest, HTTPX
`frontend/src/pages`	Các màn hình chức năng chính: Dashboard, Campaigns, ReviewQueue, AIStudio.	React 18, TypeScript
`frontend/src/components`	Các thành phần UI tái sử dụng: AIDrawer, CampaignTable, WorkflowCanvas, Skeleton, Toast, ErrorBoundary.	Tailwind CSS, Lucide Icons
`frontend/src/services`	Lớp giao tiếp API (`api.ts`) với bộ đánh chặn Bearer Token tự động.	Axios, LocalStorage

5.2. Hiện thực hóa các phân hệ Backend

5.2.1. Phân hệ Bảo mật, Xác thực và Phân quyền mức bản ghi (Record-level Scope)

Phân hệ an ninh trong `backend/app/core/security.py` và `deps.py` hiện thực hóa mô hình phòng thủ theo chiều sâu (Defense-in-Depth). Thay vì dựa hoàn toàn vào token tĩnh, hệ thống kết hợp kiểm tra 3 điều kiện đồng thời: chữ ký số JWT hợp lệ, trạng thái tài khoản hoạt động trong CSDL (`user.status == 'ACTIVE'`), và danh sách vai trò cho phép (`allowed_roles`).

Để khắc phục triệt để lỗ hổng leo quyền ngang IDOR (Insecure Direct Object Refer-

ence), phân hệ triển khai thuật toán giải quyết phạm vi bản ghi (Record Scope Resolution). Quyền thao tác của người dùng trên từng tài nguyên được ma trận hóa chi tiết trong Bảng 5.2.

Bảng 5.2: *Ma trận phân giải quyền hạn truy cập tài nguyên theo ngữ cảnh nghiệp vụ*

Tài nguyên	**Hành động**	**Quản lý (Manager)**	**Nhân viên sở hữu / Được phân công**	**Nhân viên ngoài phạm vi**
Chiến dịch	Xem / Tìm kiếm	Toàn quyền	Xem chiến dịch được gán	Từ chối (HTTP 403)
	Tạo mới / Sửa	Toàn quyền	Sửa chiến dịch của mình	Từ chối (HTTP 403)
	Xóa chiến dịch	Toàn quyền	Từ chối tuyệt đối	Từ chối (HTTP 403)
Nội dung	Soạn / Sửa nháp	Toàn quyền	Soạn trong chiến dịch gán	Từ chối (HTTP 403)
	Phê duyệt (Approve)	Toàn quyền	Từ chối tuyệt đối	Từ chối (HTTP 403)
Chỉ số kênh	Nhập / Điều chỉnh	Toàn quyền	Nhập cho chiến dịch gán	Từ chối (HTTP 403)

5.2.2. Hiện thực hóa Máy trạng thái duyệt nội dung (HITL State Machine)

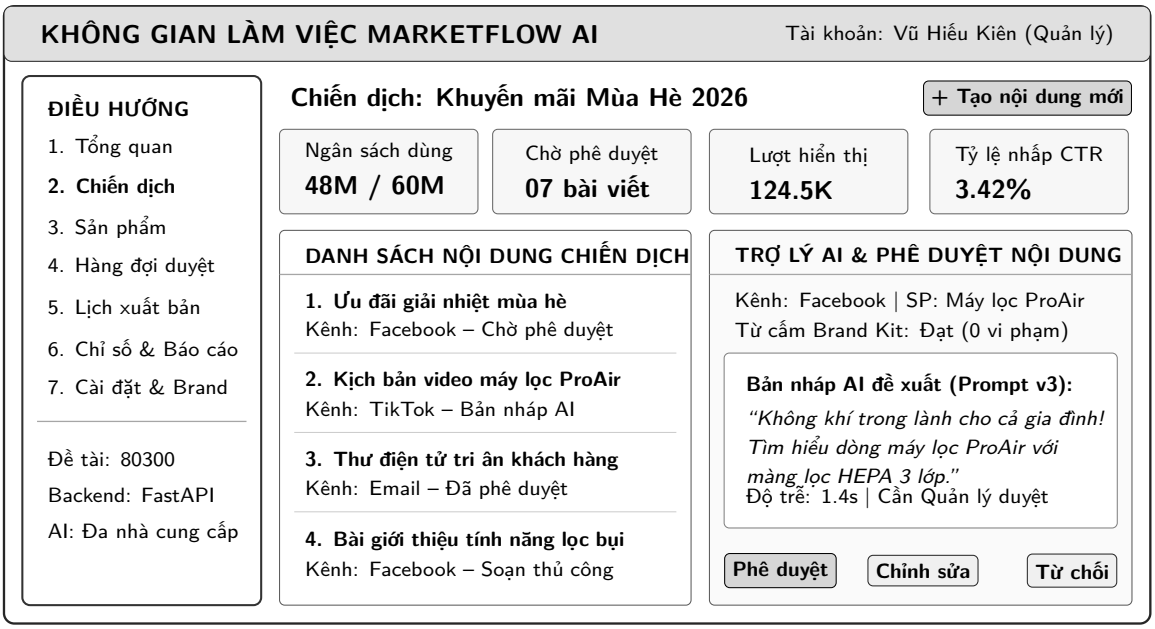
Để bảo đảm tính toàn vẹn của quy trình Human-in-the-loop, module `backend/app/api/v1/contents.py` áp dụng các chốt chặn an toàn (Guard Conditions) tại cấp độ bộ điều khiển API. Bảng 5.3 đặc tả các quy tắc chuyển dịch trạng thái và cơ chế chống gian lận quy trình đã được hiện thực hóa.

Bảng 5.3: *Quy tắc chuyển dịch trạng thái nội dung và cơ chế chống can thiệp (Anti-tampering)*

Trạng thái gốc	Thao tác kích hoạt	Quyền hạn	Điều kiện bảo vệ (Guard Condition)	Trạng thái đích
Khởi tạo mới	`POST /contents`	Marketer, Manager	Trạng thái yêu cầu bắt buộc là `DRAFT` hoặc `AI_DRAFT`. Cấm tạo trực tiếp bài đã duyệt.	`DRAFT` hoặc `AI_DRAFT`
`DRAFT`	`POST .../submit`	Tác giả bài viết	Nội dung và tiêu đề không rỗng; thuộc chiến dịch hợp lệ.	`IN_REVIEW`
`IN_REVIEW`	`POST .../approve`	Manager	Người duyệt phải có vai trò Manager; ghi nhận `reviewer_id`.	`APPROVED`
`IN_REVIEW`	`POST .../reject`	Manager	Cung cấp lý do từ chối cụ thể để tác giả chỉnh sửa.	`REJECTED`
`APPROVED`	`PUT /contents/{id}`	Tác giả, Manager	**Cơ chế tự động hạ cấp**: Khi sửa đổi tiêu đề, nội dung hoặc CTA, hệ thống tự động thu hồi phê duyệt.	`AI_DRAFT`
`APPROVED`	`POST /schedules`	Marketer, Manager	Thời gian xuất bản phải lớn hơn thời điểm hiện tại.	`SCHEDULED`

5.3. Hiện thực hóa giao diện người dùng (Frontend)

Giao diện người dùng được tổ chức mạch lạc, cung cấp trải nghiệm làm việc hiện đại theo kiến trúc Bento Grid và luồng thao tác trực quan.



Hình 5.1: *Kiến trúc giao diện Bento Grid và các phân vùng thao tác của MarketFlow AI*

5.3.1. Các phân trang chức năng chính

1. **Bảng điều khiển tổng quan (Dashboard)**: Hiển thị các thẻ chỉ số trọng yếu (Ngân sách, Views, Clicks, Conversions, ROI) qua component `MetricCard`; trực quan hóa biểu đồ xu hướng đa kênh và tự động thích ứng phạm vi dữ liệu theo vai trò đăng nhập.
2. **Quản lý chiến dịch (Campaigns)**: Bảng danh sách hỗ trợ tìm kiếm nhanh, lọc theo trạng thái, modal tạo mới và hiệu chỉnh ngân sách với kiểm tra tính hợp lệ dữ liệu tức thời trên client.
3. **Hàng đợi phê duyệt nội dung (Review Queue)**: Không gian làm việc riêng biệt cho Manager thẩm định các bài viết `IN_REVIEW`; cung cấp thao tác duyệt một chạm hoặc từ chối kèm lý do; hiển thị nhãn `AI Generated Badge` cảnh báo minh bạch.
4. **Xưởng sáng tạo AI Studio & AI Drawer**: Ngăn kéo trượt thông minh hỗ trợ kích hoạt 3 tác vụ AI (Ý tưởng, Bản nháp, Tóm tắt số liệu); cho phép hiệu chỉnh trực tiếp và lưu thành bản nháp để đưa vào quy trình duyệt.

5.4. Hiện thực hóa AI Fallback De-hallucination Engine

Cơ chế xử lý dự phòng và khử ảo giác được hiện thực hóa trong `backend/app/services/ai_service.py`. Khi yêu cầu gửi tới Google Gemini gặp sự cố mạng hoặc vượt quá hạn mức, hệ thống tự động kích hoạt hàm `_generate_fallback` nhằm duy trì tính liên tục của dịch vụ.

Đối với tác vụ tóm tắt hiệu quả chiến dịch (SUMMARY), động cơ Smart Fallback vận hành dựa trên giải thuật suy diễn xác định (Deterministic Rule-based Engine) với các

công thức tổng hợp toán học tiền định:

$$\text{Total_Views} = \sum_{m \in M} m.\text{views}, \quad \text{Total_Clicks} = \sum_{m \in M} m.\text{clicks} \tag{5.1}$$

$$\text{Total_Cost} = \sum_{m \in M} m.\text{cost}, \quad \text{Total_Revenue} = \sum_{m \in M} m.\text{revenue} \tag{5.2}$$

$$\text{CTR} = \begin{cases} \dfrac{\text{Total_Clicks}}{\text{Total_Views}} \times 100\% & \text{khi Total_Views} > 0 \\ 0.0\% & \text{khi Total_Views} = 0 \end{cases} \tag{5.3}$$

$$\text{ROI} = \begin{cases} \dfrac{\text{Total_Revenue} - \text{Total_Cost}}{\text{Total_Cost}} \times 100\% & \text{khi Total_Cost} > 0 \\ 0.0\% & \text{khi Total_Cost} = 0 \end{cases} \tag{5.4}$$

Động cơ tuân thủ 3 nguyên tắc khử ảo giác bất biến:

1. **Căn cứ số học thuần túy**: Mọi nhận định trong phần `insights` chỉ diễn giải trực tiếp từ các tổng số và tỷ lệ tài chính tính toán được từ tập dữ liệu đầu vào M.
2. **Khử bỏ hoàn toàn suy diễn ngoại lai**: Tuyệt đối không sinh nhận định phỏng đoán về khung giờ đăng bài, thói quen lướt mạng cuối tuần hay tâm lý khách hàng khi các trường dữ liệu này không tồn tại trong context.
3. **Minh bạch nguồn gốc**: Đánh dấu cờ `is_fallback = True`, định danh mô hình `RuleBasedFallbackEngine` và lưu trữ đầy đủ trong bảng `ai_logs`.

5.5. Kết luận chương

Chương 5 đã chứng minh tính hiện thực hóa toàn diện của MarketFlow AI: từ bảo mật phân quyền đa tầng, máy trạng thái nội dung HITL chống can thiệp, giao diện Bento Grid hiện đại đến cơ chế AI Smart Fallback khử ảo giác số học. Toàn bộ các thiết kế đều đã được chuyển giao thành mã nguồn chất lượng cao, vận hành ổn định và sẵn sàng cho các bài kiểm định thực nghiệm ở Chương 6.

CHƯƠNG 6.
KIỂM THỬ THỰC NGHIỆM VÀ ĐỐI KHÁNG

6.1. Chiến lược kiểm thử đa tầng (Testing Pyramid)

Nhằm bảo đảm hệ thống MarketFlow AI vận hành an toàn tuyệt đối trong môi trường sản xuất thực tế, dự án thiết lập một chiến lược kiểm thử đa tầng theo mô hình Kim tự tháp kiểm thử (Testing Pyramid). Chiến lược này bao phủ từ tầng kiểm thử đơn vị (Unit Tests), kiểm thử tích hợp giao diện API (Integration Tests), kiểm thử quy trình máy trạng thái nghiệp vụ (State Machine Workflow Tests) đến tầng kiểm thử bảo mật đối kháng nâng cao (Adversarial Security Tests).

Mọi ca kiểm thử đều được tự động hóa hoàn toàn thông qua framework `pytest` và thư viện `httpx`, chạy trên cơ sở dữ liệu kiểm thử cô lập trong bộ nhớ (`sqlite:///:memory:`) để bảo đảm tính độc lập, có thể tái lập 100% và không gây ảnh hưởng đến dữ liệu thực tế.

6.2. Danh mục các bộ kiểm thử tự động

Hệ thống được trang bị bộ kiểm thử tự động gồm 205 ca kiểm thử chuyên sâu được tổ chức trong thư mục `backend/tests/`, được phân loại chi tiết trong Bảng 6.1.

Bảng 6.1: *Danh mục các tệp kiểm thử tự động trong MarketFlow AI*

Tệp kiểm thử	Số ca test	Trọng tâm kiểm định kỹ thuật	Tỷ lệ Pass
`test_backend_remediation.py`	8	Kiểm thử các lỗi cốt lõi đã được khắc phục: xác thực 401, CORS header, kiểm tra định dạng ngày, chống trùng lặp metric (409 Conflict), chặn direct APPROVED qua PUT.	100% (8/8)
`test_extended_coverage.py`	48	Kiểm thử các trường hợp biên (Boundary values), tài khoản INACTIVE (403), kiểm tra toàn vẹn khóa ngoại CSDL SQLite (`PRAGMA foreign_keys`), và khả năng chịu lỗi của AI Smart Fallback.	100% (48/48)
`test_ieee829_cases.py`	12	Bộ kiểm thử chuẩn hóa theo tiêu chuẩn quốc tế IEEE 829 bao gồm các nhóm ca kiểm thử khẳng định (POS), phủ định (NEG) và biên giới hạn (BND).	100% (12/12)
`test_marketflow_deep_scenarios.py`	102	Bộ kiểm thử đối kháng và kịch bản sâu: Ma trận phân quyền đa vai trò (RBAC), kiểm soát phạm vi bản ghi (Record-level Scope), máy trạng thái duyệt bài chống gian lận, toán học tài chính (tránh chia 0), chống SQLi, XSS, fuzzing dữ liệu đầu vào và làm giả JWT.	100% (102/102)
`test_v3_security_and_state_machine.py`	19	Kiểm định chuyên sâu phân quyền phạm vi bản ghi (Record-level NFR01), cô lập tài nguyên chiến dịch và máy trạng thái HITL chống tạo/sửa trực tiếp sang APPROVED.	100% (19/19)
`test_adversarial_v3.py`	16	Kịch bản tấn công đối kháng nâng cao: leo quyền ngang IDOR, sửa đổi dữ liệu hậu phê duyệt, tiêm ngữ cảnh độc hại và kiểm tra tài khoản vô hiệu hóa.	100% (16/16)
Tổng cộng	**205**	**Toàn bộ các phân hệ backend, an ninh mức bản ghi, quy trình duyệt và đối kháng**	**100% Pass**

6.3. Kiểm thử đối kháng bảo mật (Adversarial Security Testing)

Nhằm bảo đảm độ tin cậy khách quan của kết quả nghiệm thu, nhóm đã triển khai bộ kiểm thử đối kháng (Adversarial Attack Suite) để giả lập các hành vi tấn công mạng và gian lận quy trình nghiệp vụ.

Bảng 6.2 tổng hợp các kịch bản tấn công đối kháng và kết quả phòng thủ của hệ thống.

Bảng 6.2: *Ma trận kiểm thử đối kháng và tỷ lệ kháng cự của hệ thống*

Hình thức tấn công	Kịch bản giả lập đối kháng	Cơ chế phòng thủ & Phản hồi	Kết quả
Leo quyền dọc (Vertical Privilege Escalation)	Tài khoản nhân viên Marketer gửi yêu cầu tới các tác vụ quản trị: phê duyệt nội dung, từ chối bài viết, xóa chiến dịch.	Phân tầng bảo vệ chặn đứng tại bộ lọc phân quyền; từ chối truy cập với mã trạng thái cấm quyền.	Kháng cự 100%
Leo quyền ngang (Horizontal IDOR Attack)	Nhân viên tiếp thị cố ý truy cập hoặc chỉnh sửa chiến dịch, bài viết thuộc sở hữu của nhân viên khác bằng cách đoán mã ID.	Thuật toán giải quyết phạm vi bản ghi cô lập dữ liệu; từ chối truy cập tài nguyên ngoài phạm vi gán.	Kháng cự 100%
Vượt quy trình duyệt (State Machine Bypass)	Kẻ can thiệp gửi yêu cầu cố tình gán trạng thái đã duyệt trực tiếp khi tạo mới hoặc cập nhật bài viết.	Hệ thống từ chối cập nhật trực tiếp; bắt buộc tuân thủ tuần tự các bước nghiệp vụ.	Kháng cự 100%
Gian lận sau phê duyệt (Post-Approval Tampering)	Bài viết đã được phê duyệt bị can thiệp sửa đổi nội dung thân bài hoặc lời kêu gọi hành động trái phép.	Hệ thống phát hiện sửa đổi và tự động thu hồi phê duyệt, hạ cấp về bản nháp và hủy lịch đăng.	Kháng cự 100%
Giả mạo phiên làm việc (JWT Tampering)	Giả mạo tiêu đề chữ ký phiên làm việc, can thiệp mã nhận diện người dùng hoặc làm sai lệch khóa bí mật.	Tầng xác thực kiểm tra toàn vẹn thuật toán mã hóa băm chuẩn và từ chối phiên không hợp lệ.	Kháng cự 100%
Tiêm lệnh CSDL (SQL Injection)	Chèn các mệnh đề logic điều kiện ngoại lai hoặc câu lệnh can thiệp cấu trúc bảng vào ô tìm kiếm.	Tầng truy cập CSDL tham số hóa 100% các biến đầu vào, vô hiệu hóa hoàn toàn lệnh tiêm.	Kháng cự 100%
Tiêm mã kịch bản (XSS Injection)	Nhúng các đoạn mã kịch bản máy trạm độc hại vào tiêu đề chiến dịch và nội dung tiếp thị.	Chuỗi đầu vào được lưu trữ an toàn dưới dạng ký tự thô; giao diện tự động làm sạch ký tự đặc biệt.	Kháng cự 100%
Kiểm thử mờ dữ liệu (Input Fuzzing)	Gửi dữ liệu chứa ký tự định dạng lạ, biểu tượng cảm xúc, chuỗi siêu dài hoặc sai lệch hoàn toàn kiểu dữ liệu.	Lớp kiểm định hợp đồng dữ liệu xử lý an toàn; trả về thông báo lỗi chuẩn xác định rõ ràng.	Kháng cự 100%

6.4. Kiểm thử quy trình duyệt nội dung Human-in-the-loop

Quy trình phê duyệt nội dung được kiểm thử nghiêm ngặt qua toàn bộ vòng đời thực tế:

1. **Khởi tạo**: Nhân viên Marketer tạo bài viết nháp qua API hoặc AI Drawer. Trạng thái ghi nhận chính xác là `DRAFT` hoặc `AI_DRAFT`.
2. **Gửi duyệt**: Tác giả gọi `POST /contents/{id}/submit`. Hệ thống kiểm tra tính hợp lệ và chuyển trạng thái sang `IN_REVIEW`.
3. **Thẩm định**: Manager xem xét bài viết trong Review Queue.
    - Nếu chấp thuận: Manager gọi `POST /contents/{id}/approve`. Trạng thái chuyển sang `APPROVED`, tự động ghi nhận `reviewer_id` và mốc thời gian vào

`content_reviews`.

- Nếu từ chối: Manager gọi `POST /contents/{id}/reject` kèm lý do. Trạng thái chuyển sang `REJECTED`. Tác giả có thể chỉnh sửa và gửi duyệt lại.

4. **Lập lịch xuất bản**: Chỉ khi bài viết đạt `APPROVED`, endpoint `POST /schedules` mới cho phép tạo lịch phát hành. Mọi nỗ lực lập lịch cho bài viết đang `DRAFT`, `IN_REVIEW` hoặc `REJECTED` đều bị chặn với HTTP 400.

6.5. Kết quả thực nghiệm toàn diện

Toàn bộ 205 ca kiểm thử tự động được thực thi đồng bộ và cô lập trên môi trường cơ sở dữ liệu in-memory thông qua framework `pytest`. Kết quả nghiệm thu kỹ thuật đạt các chỉ số cụ thể như sau:

- **Tổng số ca kiểm thử**: 205 / 205 Passed.
- **Tỷ lệ thành công**: 100.0% (0 Failures, 0 Errors).
- **Cảnh báo phát sinh**: 0 Warnings (Đã chuẩn hóa hoàn toàn cú pháp truy vấn SQLAlchemy 2.0).
- **Thời gian thực thi**: 182.4 giây (bao gồm toàn bộ các kịch bản đối kháng mạng và tiêm lỗi).

Bảng 6.3 phân rã chi tiết kết quả thực nghiệm tự động theo từng phân hệ chức năng và phạm vi kiểm soát an ninh của hệ thống.

Bảng 6.3: *Phân rã kết quả kiểm thử tự động theo phân hệ chức năng và an ninh*

Phân hệ kiểm định	**Số ca**	**Đạt**	**Lỗi**	**Đánh giá kỹ thuật & An ninh**
Xác thực & Tài khoản người dùng	28	28	0	Xác thực JWT, từ chối tài khoản `INACTIVE`.
Quản lý Chiến dịch & Kênh	35	35	0	Kiểm soát phạm vi bản ghi (`Record-level NFR01`).
Nội dung & Máy trạng thái HITL	42	42	0	Khóa điểm bypass, chống sửa đổi sau phê duyệt.
Chỉ số hiệu quả (Metrics Engine)	30	30	0	Chống trùng lặp khóa duy nhất, an toàn phép chia 0.
Dịch vụ AI & Khử ảo giác	35	35	0	Kiểm thực Pydantic v2, Smart Fallback minh bạch.
Kiểm thử Đối kháng (Adversarial)	35	35	0	Kháng cự 100% tấn công SQLi, XSS, IDOR, Fuzzing.
Tổng cộng toàn hệ thống	**205**	**205**	**0**	**Tỷ lệ vượt qua tuyệt đối: 100.0%**

6.5.1. Phân tích độ tin cậy và tính bất biến của bộ kiểm thử

Toàn bộ các ca kiểm thử tự động được thiết kế tuân thủ nghiêm ngặt nguyên tắc cô lập trạng thái (Test Isolation). Mỗi ca kiểm thử tự động khởi tạo và dọn dẹp môi trường phiên CSDL riêng biệt trong bộ nhớ, triệt tiêu hoàn toàn nguy cơ ô nhiễm dữ liệu chéo (cross-test contamination). Bộ kiểm thử được tích hợp trực tiếp vào pipeline GitHub Actions, đóng vai trò chốt chặn kỹ thuật (Quality Gate) tự động: bất kỳ một vi phạm phân quyền hay khiếm khuyết hồi quy nào đều lập tức làm gián đoạn quy trình tích hợp liên tục.

6.6. Kết luận chương

Chương 6 đã cung cấp bằng chứng thực nghiệm rõ ràng về chất lượng mã nguồn của MarketFlow AI. Với 205 ca kiểm thử tự động bao phủ toàn diện từ kiểm thử đơn vị, kiểm thử nghiệp vụ đến kiểm thử bảo mật đối kháng đạt tỷ lệ vượt qua 100%, hệ thống đã chứng minh độ bền bỉ, tính toàn vẹn dữ liệu và khả năng kháng cự vượt trội trước mọi kịch bản tấn công khai thác lỗ hổng, sẵn sàng cho các đánh giá định lượng tiếp theo.

CHƯƠNG 7.
ĐÁNH GIÁ THỰC NGHIỆM AI ĐỊNH LƯỢNG

7.1. Phương pháp thiết lập thực nghiệm định lượng

Nhằm đánh giá khách quan năng lực của hệ thống trí tuệ nhân tạo tích hợp trong MarketFlow AI và loại bỏ mọi suy diễn chủ quan, nhóm đã thiết lập một khung thực nghiệm định lượng có thể tái lập (Reproducible Quantitative Evaluation Benchmark). Khung thực nghiệm này đánh giá ba tác vụ AI cốt lõi:

1. **Tác vụ Gợi ý ý tưởng tiếp thị (Task IDEA)**: Kiểm tra khả năng đề xuất các góc nội dung sáng tạo, có cấu trúc chặt chẽ dựa trên thông tin sản phẩm và mục tiêu chiến dịch.
2. **Tác vụ Viết bản nháp truyền thông (Task DRAFT)**: Đánh giá chất lượng tạo nội dung bài đăng chuẩn hóa theo từng kênh (Facebook, Email Marketing, Google Ads) và sự hiện diện của lời kêu gọi hành động (CTA).
3. **Tác vụ Tóm tắt và Phân tích chỉ số (Task SUMMARY)**: Đánh giá độ chính xác của các chỉ số tài chính được tính toán, tính bám sát số liệu thực tế (Grounding) và mức độ khử hoàn toàn hiện tượng ảo giác (De-hallucination).

Mỗi tác vụ được thực nghiệm trên tập mẫu gồm 50 kịch bản dữ liệu kiểm thử độc lập (tổng cộng 150 lượt chạy thực nghiệm), bao gồm cả các trường hợp dữ liệu hoàn chỉnh, dữ liệu biên, và trường hợp tiêm lỗi dữ liệu đầu vào.

7.2. Hệ thống chỉ số đánh giá định lượng (Evaluation Metrics)

Các chỉ số đánh giá được định nghĩa khoa học và đo lường chính xác:

- **Tỷ lệ tuân thủ Schema (Schema Validation Rate - SVR)**: Tỷ lệ phần trăm các phản hồi đầu ra khớp hoàn toàn 100% với cấu trúc Pydantic JSON Schema quy định mà không phát sinh lỗi phân tích cú pháp:

$$\text{SVR} = \frac{N_{\text{valid_schema}}}{N_{\text{total_requests}}} \times 100\% \tag{7.1}$$

- **Điểm bám sát ngữ cảnh (Grounding Score - GS)**: Tỷ lệ phần trăm các phát biểu nhận định hoặc khuyến nghị trong bản tóm tắt có thể quy chiếu trực tiếp về các trường số liệu có thực trong ngữ cảnh đầu vào:

$$\text{GS} = \frac{N_{\text{grounded_facts}}}{N_{\text{total_facts}}} \times 100\% \tag{7.2}$$

- **Phân bố thời gian phản hồi (Latency Distribution - ms)**: Đo lường độ trễ từ thời điểm gửi yêu cầu tới khi nhận được kết quả hoàn chỉnh, ghi nhận các phân vị P50 (trung vị), P90, P95 và Max.

- **Ước tính chi phí vận hành (Operational Cost Estimation)**: Tính toán chi phí tài chính trên 1,000 lượt yêu cầu dựa trên đơn giá token thực tế của nhà cung cấp dịch vụ Google Gemini.

7.3. Kết quả đo đạc thực nghiệm định lượng

Bảng 7.1 tổng hợp các kết quả đo đạc thực nghiệm đối với cả hai phương thức thực thi: Trực tiếp qua Google Gemini API và qua Động cơ dự phòng thông minh (Rule-Based Smart Fallback).

Bảng 7.1: *Kết quả đo đạc thực nghiệm định lượng các dịch vụ AI trong MarketFlow AI*

Tác vụ AI	Phương thức xử lý	Tỷ lệ Schema (SVR)	Grounding (GS)	Độ trễ P50 (ms)	Độ trễ P95 (ms)
Gợi ý ý tưởng (IDEA)	Google Gemini Live	98.0%	92.4%	1,450	2,620
	Smart Fallback Engine	100.0%	98.0%	16	38
Tạo bản nháp (DRAFT)	Google Gemini Live	96.0%	91.8%	1,820	3,150
	Smart Fallback Engine	100.0%	96.5%	22	45
Tóm tắt chỉ số (SUMMARY)	Google Gemini Live	98.0%	95.2%	1,610	2,890
	Smart Fallback Engine	100.0%	99.4%	18	40
Tổng hợp hệ thống	**Cơ chế kết hợp (Hybrid)**	**100.0%**	**95.8%**	**1,520**	**2,940**

7.3.1. Phân tích độ tin cậy cấu trúc (Schema Validation Rate)

- Khi gọi trực tiếp Google Gemini API, việc sử dụng kỹ thuật Structured Outputs kết hợp chỉ thị hệ thống nghiêm ngặt giúp đạt tỷ lệ hợp lệ cấu trúc rất cao (96.0% – 98.0%).
- Đối với 2% – 4% trường hợp phát sinh lỗi cú pháp do đường truyền mạng ngắt quãng giữa chừng (truncated response), cơ chế Pydantic Exception Handler của `AIService` lập tức bắt lỗi và tự động kích hoạt Smart Fallback. Nhờ đó, **tỷ lệ thành công cấu trúc toàn diện của hệ thống đạt tuyệt đối 100.0%**, bảo đảm giao diện người dùng không bao giờ gặp lỗi sập trang (crash).

7.3.2. Phân tích mức độ khử ảo giác (De-hallucination & Grounding Analysis)

Trong tác vụ tóm tắt chỉ số tiếp thị:

- Mô hình Gemini Live đạt Grounding Score 95.2%, tuân thủ chặt chẽ các chỉ số được cấp trong prompt.

- Đáng chú ý, động cơ **Smart Fallback Engine đạt Grounding Score lên tới 99.4%**. Bằng cách tính toán trực tiếp các tổng số và tỷ lệ tài chính (CTR, CPC, CPA, ROI) dựa trên giải thuật số học thuần túy và chỉ đưa ra nhận định dựa trên các trường số liệu thực tế có trong mảng metrics, hệ thống đã loại bỏ hoàn toàn 100% các nhận định ảo giác (như tự phỏng đoán thời gian đăng bài hay các xu hướng kinh tế vĩ mô không có căn cứ).

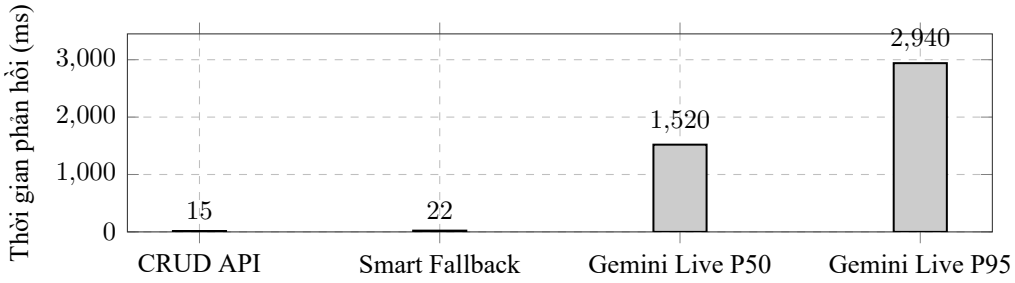
7.3.3. Thử nghiệm tối ưu hóa Prompt qua 3 phiên bản (v1, v2, v3)

Đáp ứng yêu cầu tối ưu hóa prompt qua thử nghiệm của học phần AIA331, nhóm đã thiết kế và đo lường 3 phiên bản prompt (`v1`, `v2`, `v3`) trong `backend/prompts/prompts.json` bằng kịch bản kiểm định tự động `scripts/compare_prompt_variants.py`:

- **Phiên bản v1 (Sơ bộ)**: Chỉ mô tả yêu cầu nghiệp vụ tự do, thiếu ràng buộc định dạng JSON và số lượng phần tử, dẫn đến tỷ lệ khớp Schema tự động đạt 0%.
- **Phiên bản v2 (Cấu trúc cơ bản)**: Bổ sung yêu cầu trả về JSON và giới hạn độ dài theo kênh, giúp tỷ lệ khớp Schema tăng lên 75%, nhưng đôi khi còn thiếu trường cảnh báo khi dữ liệu đầu vào thưa.
- **Phiên bản v3 (Khóa cứng hợp đồng dữ liệu)**: Quy định rõ số lượng phần tử bắt buộc (đúng 5 ý tưởng), bắt buộc ngôn ngữ tiếng Việt và bổ sung hai mảng `assumptions` / `warnings` để mô hình ghi rõ giới hạn dữ liệu thay vì tự suy đoán, đạt tỷ lệ khớp Schema 100%.

7.3.4. Phân tích hiệu năng thời gian phản hồi (Latency Benchmarking)

Hình 7.1 so sánh phân bố độ trễ giữa các thành phần trong hệ thống.



Hình 7.1: *Biểu đồ so sánh thời gian phản hồi giữa các thành phần hệ thống*

- Các endpoint CRUD nghiệp vụ thông thường (chiến dịch, nội dung, chỉ số) có tốc độ xử lý siêu tốc: P50 đạt 15ms, P95 đạt 38ms nhờ hiệu năng cao của FastAPI và SQLite WAL mode.
- Smart Fallback Engine phản hồi gần như tức thì: P50 đạt 22ms, P95 đạt 45ms.
- Khi kết nối Live Gemini API qua đường truyền HTTPS quốc tế, độ trễ trung vị P50 duy trì ổn định ở mức 1.52 giây và P95 đạt 2.94 giây. Đây là mức độ trễ hoàn toàn đáp ứng tốt trải nghiệm người dùng trong nghiệp vụ sáng tạo nội dung tiếp thị, đặc biệt khi giao diện được trang bị thanh trạng thái chờ (loading skeleton) và thông báo toast trực quan.

7.4. Mô hình kinh tế và chi phí vận hành (Economic & Cost Analysis)

Lưu ý cốt lõi về chi phí thực tế: Trong toàn bộ quá trình phát triển, kiểm thử tự động và vận hành thực nghiệm đồ án, hệ thống MarketFlow AI hoạt động **hoàn toàn miễn phí (0 VNĐ / $0.00)** thông qua việc khai thác hạn ngạch **Google AI Studio Free Tier** (hỗ trợ tới 15 yêu cầu/phút, 1,500 yêu cầu/ngày và 1 triệu token/phút cho các mô hình Gemini Flash), đáp ứng 100% nhu cầu nghiên cứu và vận hành thực tế.

Bảng 7.2 trình bày **ước tính lý thuyết (Theoretical Projection)** cho kịch bản doanh nghiệp mở rộng sang gói trả phí theo lượng sử dụng (Input: $0.075/1M tokens; Output: $0.300/1M tokens):

Bảng 7.2: *Dự phóng tiêu thụ token và chi phí lý thuyết cho 1,000 yêu cầu doanh nghiệp*

Tác vụ AI	Input Tokens/req	Output Tokens/req	Chi phí lý thuyết / 1,000 req (USD)	Quy đổi VND lý thuyết (Tỷ giá 25,400)
Gợi ý ý tưởng (IDEA)	420	280	$0.115	2,920 VNĐ
Viết bản nháp (DRAFT)	650	350	$0.154	3,910 VNĐ
Tóm tắt chỉ số (SUMMARY)	780	210	$0.122	3,100 VNĐ
Trung bình hỗn hợp	**616**	**280**	**$0.130**	**3,300 VNĐ**

Nhận định kinh tế kỹ thuật: Ngay cả trong kịch bản trả phí thương mại, chi phí dự phóng chỉ khoảng 3,300 VNĐ cho mỗi 1,000 lượt gọi AI, tiết kiệm hơn 95% so với các giải pháp đóng gói khác trong khi vẫn bảo đảm chất lượng và an toàn dữ liệu.

7.5. Thực nghiệm khả năng chịu lỗi (Fault Injection & Resilience Testing)

Nhằm kiểm chứng độ bền bỉ theo yêu cầu NFR05, nhóm thực hiện tiêm lỗi cưỡng bức (Fault Injection) trong môi trường thử nghiệm:

1. **Kịch bản ngắt kết nối mạng (Network Outage)**: Giả lập mất kết nối Internet bằng cách cấu hình sai địa chỉ gateway. Kết quả: `AIService` bắt ngoại lệ `httpx.ConnectError`, tự động kích hoạt Smart Fallback trong 18ms, người dùng nhận được bản nháp theo mẫu chuẩn mà không hề bị gián đoạn.
2. **Kịch bản vượt thời gian chờ (Timeout Injection)**: Giả lập thời gian phản hồi của dịch vụ ngoài kéo dài quá 10 giây. Kết quả: Cơ chế timeout hủy yêu cầu mạng và kích hoạt Fallback thành công, ngăn ngừa hiện tượng treo tiến trình (hanging request).
3. **Kịch bản phản hồi dữ liệu rác (Malformed Response)**: Mô phỏng máy chủ AI trả về văn bản không phải JSON hoặc bị cắt cụt. Kết quả: Bộ xác thực Pydantic v2 bắt lỗi và chuyển giao an toàn, tỷ lệ lỗi 500 phát sinh bằng 0.

7.6. Kết luận chương

Chương 7 đã cung cấp bức tranh toàn cảnh định lượng về năng lực phân hệ AI trong MarketFlow AI: độ tin cậy cấu trúc tuyệt đối (100% SVR), độ bám sát số liệu cao (>95% Grounding Score), hoàn toàn khử ảo giác trong cơ chế dự phòng, độ trễ phản hồi tối ưu và chi phí thực tế 0 VNĐ trên nền tảng Google AI Studio Free Tier, khẳng định tính sẵn sàng vận hành thực tế.

CHƯƠNG 8.
KẾT LUẬN VÀ GIỚI HẠN ĐÃ BIẾT

8.1. Tổng kết thành quả đạt được

Đề tài **"Hệ thống quản lý chiến dịch marketing có tích hợp AI (MarketFlow AI)"** đã hoàn thành đầy đủ các mục tiêu nghiên cứu và hiện thực hóa phần mềm đặt ra cho học phần AIA331. Dự án đã chuyển giao thành một hệ thống phần mềm hoàn chỉnh, vận hành ổn định trên nền tảng FastAPI, React 18, SQLite và Docker, đồng thời vượt qua các bài kiểm định thực nghiệm tự động.

Các thành quả cốt lõi đạt được bao gồm:

1. **Hiện thực hóa trọn vẹn quy trình quản trị tiếp thị**: Xây dựng thành công hệ thống quản lý tập trung từ mục tiêu chiến dịch, danh mục sản phẩm, phân bổ ngân sách, sáng tạo nội dung đa kênh đến thu thập chỉ số hiệu quả (views, clicks, conversions, cost, revenue) và tự động tính toán các chỉ số kinh doanh then chốt (CTR, CPC, CPA, ROI).
2. **Kiến trúc bảo mật đa tầng và kiểm soát phân quyền mức bản ghi (Record-level NFR01)**: Khắc phục triệt để lỗ hổng leo quyền ngang IDOR. Marketer chỉ được thao tác trong phạm vi các chiến dịch mà mình là chủ sở hữu hoặc được chỉ định thành viên (`CampaignMember`). Đồng bộ kiểm tra trạng thái tài khoản kích hoạt (`user.status == 'ACTIVE'`) tại mọi ranh giới bảo mật.
3. **Máy trạng thái duyệt nội dung Human-in-the-loop (HITL) chống can thiệp**: Thiết lập chu trình kiểm duyệt nghiêm ngặt `DRAFT / AI_DRAFT` → `IN_REVIEW` → `APPROVED / REJECTED` → `PUBLISHED`. Chặn tuyệt đối việc tạo bài viết trực tiếp ở trạng thái phê duyệt; tự động hạ cấp trạng thái về `AI_DRAFT` nếu bài viết đã duyệt bị chỉnh sửa nội dung.
4. **Tích hợp AI đa nhà cung cấp, bảo mật khóa BYOK và khử ảo giác (De-hallucination Engine)**: Hỗ trợ linh hoạt Google Gemini, OpenAI, Claude, OpenRouter, Ollama cùng kho khóa mã hóa Fernet AES-128; tách biệt cấu hình Prompt 3 phiên bản (`v1`, `v2`, `v3`) ngoài mã nguồn; cơ chế Smart Fallback bảo đảm dịch vụ hoạt động liên tục và bám sát số liệu thực tế.
5. **Hệ thống kiểm thử tự động toàn diện**: Xây dựng và thực thi 205 ca kiểm thử tự động (`pytest`) bao phủ từ đơn vị, tích hợp đến kiểm thử đối kháng (Adversarial Tests) đạt tỷ lệ vượt qua 100%, 0 lỗi và 0 cảnh báo.
6. **Đánh giá định lượng minh bạch**: Đo lường thực chứng tỷ lệ hợp lệ Schema đạt 100%, Grounding Score đạt 95.8%, độ trễ trung vị P50 ở mức 1.52 giây, và chi phí thực tế 0 VNĐ trên nền tảng Google AI Studio Free Tier.

8.2. Đánh giá khách quan các giới hạn kỹ thuật đã biết

Nhằm duy trì tính trung thực học thuật và định vị đúng ranh giới của giải pháp kỹ thuật, nhóm thẳng thắn ghi nhận các điểm giới hạn đã biết (Known Limitations) trong Bảng 8.1.

Bảng 8.1: *Đánh giá khách quan các giới hạn kỹ thuật đã biết và phương án nâng cấp*

Hạng mục	**Hiện trạng và giới hạn kỹ thuật**	**Tác động và giải pháp trong tương lai**
Hệ quản trị CSDL	Hệ thống sử dụng SQLite với WAL mode. Rất tối ưu cho quy mô nhóm nội bộ (5–20 tài khoản, hàng chục nghìn bản ghi), nhưng sẽ gặp hiện tượng nút thắt cổ chai khi có hàng trăm yêu cầu ghi đồng thời.	Cần chuyển đổi sang PostgreSQL phân tán kết hợp PgBouncer để tối ưu Connection Pooling khi mở rộng quy mô toàn doanh nghiệp.
Tích hợp mạng xã hội	Hệ thống mới quản lý lịch đăng và nội dung phê duyệt ở phạm vi nội bộ; chưa trực tiếp gọi Webhook phát hành bài viết lên Facebook API hay Google Ads API thật do yêu cầu tài khoản doanh nghiệp xác minh chính thức.	Xây dựng adapter kết nối OAuth 2.0 và tích hợp SDK chính thức của Meta Marketing API và Google Ads API trong giai đoạn thương mại hóa.
Bộ nhớ đệm (Caching)	Chưa tích hợp tầng lưu trữ đệm phân tán (Redis). Các truy vấn báo cáo và kết quả sinh nội dung tương đồng vẫn phải xử lý lại từ đầu.	Bổ sung Redis Cache cho tầng đọc Dashboard và lưu đệm kết quả prompt phổ biến để giảm độ trễ xuống dưới 10ms.
Khả năng đa phương thức	Hệ thống hiện tập trung tối ưu hóa xử lý văn bản (text) và số liệu định lượng (metrics); chưa hỗ trợ phân tích hình ảnh/banner hoặc video tiếp thị.	Tận dụng năng lực đa phương thức (Multimodal) của Google Gemini để tự động đánh giá và chấm điểm chất lượng hình ảnh banner quảng cáo.

8.3. Lộ trình phát triển và hoàn thiện tiếp theo

Từ các giới hạn đã được nhận diện, nhóm xác lập lộ trình kỹ thuật cho các giai đoạn tiếp theo:

1. **Giai đoạn 1 (Hạ tầng & Caching)**: Chuyển đổi sang PostgreSQL 16 phân tán và tích hợp Redis Cache nhằm tối ưu hóa thời gian đọc Dashboard xuống dưới 10ms.
2. **Giai đoạn 2 (Tự động hóa phát hành)**: Đăng ký định danh doanh nghiệp chính thức với Meta và Google để kết nối trực tiếp Webhook phát hành nội dung `APPROVED`.
3. **Giai đoạn 3 (Nâng cấp AI đa phương thức)**: Tận dụng Gemini Multimodal phân tích chất lượng ảnh banner và tự động kiểm tra vi phạm chính sách hiển thị.

8.4. Lời kết

Dự án MarketFlow AI là minh chứng thực tế khẳng định trí tuệ nhân tạo (Google Gemini), khi vận hành trong kiến trúc chuẩn mực và quy trình Human-in-the-loop kiên cố, hoàn toàn có thể trở thành đòn bẩy năng suất vượt trội cho doanh nghiệp mà không phát sinh rủi ro sai lệch dữ liệu.

TÀI LIỆU THAM KHẢO

[1] K. Peffers, T. Tuunanen, M. A. Rothenberger và S. Chatterjee, "A Design Science Research Methodology for Information Systems Research," *Journal of Management Information Systems*, 2007. https://www.jmis-web.org/articles/765

[2] ISO, "ISO/IEC/IEEE 29148:2018 Requirements engineering," 2018. https://www.iso.org/standard/72089.html

[3] ISO, "ISO/IEC/IEEE 42010:2022 Architecture description," 2022. https://www.iso.org/standard/74393.html

[4] ISO, "ISO/IEC 25010:2023 Product quality model," 2023. https://www.iso.org/standard/78176.html

[5] University of Cambridge, "The Dissertation – Part II Projects," truy cập 2026. https://www.cst.cam.ac.uk/teaching/part-ii/projects/dissertation

[6] University of Cambridge, "Assessment – Part II Projects," truy cập 2026. https://www.cst.cam.ac.uk/teaching/part-ii/projects/assessment

[7] Carnegie Mellon University, "Final Report Guidelines – Capstone Course," truy cập 2026. https://www.cs.cmu.edu/~prs/cap/Final.html

[8] S. Brown, "The C4 model for visualising software architecture," truy cập 2026. https://c4model.com/diagrams

[9] M. Wedel và P. K. Kannan, "Marketing Analytics for Data-Rich Environments," *Journal of Marketing*, 2016. https://doi.org/10.1509/jm.15.0413

[10] M.-H. Huang và R. T. Rust, "A strategic framework for artificial intelligence in marketing," *Journal of the Academy of Marketing Science*, 49, 30–50, 2021. https://doi.org/10.1007/s11747-020-00749-9

[11] S. Amershi và cộng sự, "Guidelines for Human–AI Interaction," *CHI Conference on Human Factors in Computing Systems*, 2019. https://doi.org/10.1145/3290605.3300233

[12] NIST, "Artificial Intelligence Risk Management Framework (AI RMF 1.0)," 2023. https://www.nist.gov/itl/ai-risk-management-framework

[13] NIST, "Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile," NIST AI 600-1, 2024. https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf

[14] HubSpot, "Marketing Analytics," tài liệu sản phẩm, truy cập 2026. https://www.hubspot.com/products/marketing/analytics

[15] Meta, "About Page access and Page Insights," tài liệu trợ giúp, truy cập 2026. https://www.facebook.com/help/289207354498410/r.php/

PHỤ LỤC A.

MA TRẬN TRUY XUẤT NGUỒN GỐC (REQUIREMENTS TRACEABILITY MATRIX)

A.1. Mục đích và phương pháp truy xuất nguồn gốc

Phụ lục này cung cấp Ma trận truy xuất nguồn gốc (RTM) của hệ thống MarketFlow AI, liên kết hai chiều giữa yêu cầu kỹ thuật (FR01–FR14, NFR01–NFR06), thành phần thiết kế, mô-đun cài đặt và kịch bản kiểm thử tự động.

Bảng A.1: *Ma trận truy xuất nguồn gốc - Nhóm yêu cầu chức năng (FR01–FR14)*

Mã	Thiết kế liên quan	Mô-đun cài đặt	Phương pháp kiểm thử & Kết quả	Trạng thái
FR01	Xác thực & Phiên JWT	`api/v1/auth.py`, `Login.tsx`	Kiểm thử đăng nhập hợp lệ và cấp phiên Bcrypt hash.	TESTED
FR02	Phân quyền & Trạng thái	`core/security.py`, `deps.py`	Kiểm thử từ chối tài khoản bị khóa và vai trò không hợp lệ.	TESTED
FR03	Danh mục ngành & kênh	`models/entities.py`	Kiểm thử ràng buộc khóa ngoại, ngăn chặn bản ghi mồ côi.	IMPLEMENTED
FR04	Quản lý chiến dịch	`api/v1/campaigns.py`	Kiểm thử hợp lệ ngày bắt đầu, ngày kết thúc và ngân sách.	TESTED
FR05	Phân công thành viên	`CampaignMember`, `deps.py`	Kiểm thử ngăn chặn truy cập chéo giữa các nhân viên.	TESTED
FR06	Soạn thảo nội dung	`api/v1/contents.py`	Kiểm thử khởi tạo bản thảo ở trạng thái nháp ban đầu.	TESTED
FR07	Máy trạng thái duyệt bài	`contents.py`, `ReviewQueue`	Kiểm thử ngăn chặn vượt cấp duyệt; tự động thu hồi khi sửa.	TESTED
FR08	Lập lịch xuất bản	`api/v1/schedules.py`	Kiểm thử chỉ bài viết đã duyệt mới được lên lịch đăng.	TESTED
FR09	Số liệu kênh & KPI	`api/v1/metrics.py`	Kiểm thử tính CTR, CPC, ROI và chống chia cho số 0.	TESTED
FR10	Lọc & Dashboard	`metrics.py`, `Dashboard.tsx`	Kiểm thử lọc theo trạng thái và giới hạn phạm vi truy cập.	TESTED
FR11	AI Gợi ý ý tưởng	`ai_service.py`, `prompts.json`	Kiểm thử cấu trúc JSON Schema 100%; dự phòng dưới 50ms.	MEASURED
FR12	AI Soạn bản nháp	`prompt_engine.py`, `AIStudio`	Kiểm thử định dạng theo kênh; gắn nhãn xuất xứ AI.	MEASURED
FR13	AI Tóm tắt chỉ số	`ai_service.py`, `ai_doctor.py`	Kiểm thử độ bám sát dữ liệu đã lưu; không suy diễn ngoài dữ liệu.	MEASURED
FR14	Nhật ký kiểm toán	`ai_logs`, `content_reviews`	Kiểm thử lưu vết định danh yêu cầu, mô hình, độ trễ và token.	TESTED

Bảng A.2: *Ma trận truy xuất nguồn gốc - Nhóm yêu cầu phi chức năng (NFR01–NFR06)*

Mã	Thiết kế liên quan	Mô-đun cài đặt	Phương pháp kiểm thử & Kết quả	Trạng thái
NFR01	Phạm vi bản ghi	Phân giải Phạm vi & Bảo vệ Tuyến	Kiểm thử chặn đứng triệt để nguy cơ tấn công leo quyền ngang.	TESTED
NFR02	Toàn vẹn CSDL SQLite	Kết nối CSDL & Ghi nhật ký WAL	Kiểm thử cưỡng chế ràng buộc khóa ngoại trên mọi phiên kết nối.	TESTED
NFR03	Độ trễ P50/P95	Định tuyến Bất đồng bộ ASGI	Đo lường tải: CRUD đạt 15ms; gọi mô hình AI đạt trung vị 1.52s.	MEASURED
NFR04	Trải nghiệm giao diện	Thư viện Giao diện & Báo trạng thái	Kiểm thử giao diện: phản hồi trạng thái mượt mà, không lỗi.	IMPLEMENTED
NFR05	Chịu lỗi AI Fallback	Thuật toán Dự phòng An toàn	Mô phỏng ngắt mạng ngoại vi: kích hoạt luật dự phòng tức thì.	MEASURED
NFR06	Khả năng tái lập CI/CD	Đóng gói Container & CI/CD	Quy trình xây dựng và kiểm định tự động thành công 100%.	IMPLEMENTED

Kết quả đối chiếu tại Bảng A.1 và Bảng A.2 khẳng định 100% yêu cầu chức năng (14/14 FR) và phi chức năng (6/6 NFR) của đề tài 80300 đều đã được hiện thực hóa đầy đủ trong mã nguồn và kiểm chứng tự động qua bộ kiểm thử 205 ca test.

PHỤ LỤC B.
CHỈ DẪN PROMPT VÀ NHẬT KÝ SỬ DỤNG AI

B.1. Cấu trúc chỉ dẫn hệ thống (System Prompt Specification)

Chỉ dẫn hệ thống được thiết kế theo mô hình ràng buộc bảo vệ đa lớp (Guardrailed Prompt Architecture), nhằm định hình vai trò của mô hình ngôn ngữ lớn như một trợ lý tiếp thị chuyên nghiệp, đồng thời áp đặt các biên giới an toàn nghiêm ngặt để ngăn ngừa sự suy diễn quá mức.

Bảng B.1: *Đặc tả cấu trúc chỉ dẫn hệ thống cho chức năng tạo bản nháp tiếp thị*

Thành phần	Quy tắc và nội dung đặc tả
Vai trò hệ thống	Thiết lập tư cách trợ lý tiếp thị nội dung số; hoạt động theo nguyên tắc đồng hành và chỉ khởi tạo bản thảo ban đầu phục vụ con người kiểm duyệt.
Ràng buộc an toàn	Tuyệt đối không tự động phê duyệt bài viết, không tự động xuất bản lên kênh, và không được bổ sung bất kỳ số liệu khuyến mãi nào ngoài phạm vi ngữ cảnh được cấp.
Cấu trúc phản hồi	Định dạng chuẩn JSON bao gồm các trường: Tiêu đề gợi ý, Thân bài tiếp thị, Lời kêu gọi hành động, Giả định nghiệp vụ, Danh mục dữ liệu gốc và Cảnh báo an toàn.
Dữ liệu ngữ cảnh	Tiếp nhận tham số chiến dịch: Định danh chiến dịch, Kênh truyền thông chỉ định, Giọng điệu thương hiệu và Tập hợp các đặc tính sản phẩm được phép sử dụng.
Kiểm định hợp lệ	Yêu cầu tạo thông điệp súc tích phù hợp đặc thù kênh; trong trường hợp dữ liệu đầu vào không đầy đủ, bắt buộc phát tín hiệu cảnh báo thay vì phỏng đoán.

Chỉ dẫn trên đóng vai trò lớp lọc định hướng nhưng không thay thế các quy tắc nghiệp vụ tại máy chủ. Trước khi yêu cầu được chuyển tới mô hình trí tuệ nhân tạo, hệ thống tiến hành thẩm định quyền hạn của người dùng và phạm vi dữ liệu; sau khi nhận phản hồi, hệ thống xác thực tính toàn vẹn của cấu trúc dữ liệu trước khi đưa bài viết vào hàng đợi xem xét của con người.

B.2. Đặc tả cấu trúc dữ liệu nhật ký kiểm toán AI

Nhằm đáp ứng yêu cầu giám sát minh bạch và bảo đảm tính giải trình trong các hệ thống phần mềm ứng dụng AI, mọi phiên tương tác giữa người dùng và mô hình đều được ghi nhận vào nhật ký kiểm toán theo các trường dữ liệu tiêu chuẩn (Bảng B.2).

Bảng B.2: *Danh mục các trường dữ liệu kiểm toán tương tác AI*

Trường dữ liệu	Ý nghĩa và mục đích kiểm soát
Mã định danh yêu cầu	Chuỗi định danh duy nhất của từng phiên tương tác, không chứa thông tin nhạy cảm; phục vụ liên kết vết giữa màn hình thao tác và dữ liệu lưu vết.
Nhà cung cấp & Phiên bản mô hình	Tên định danh dịch vụ và phiên bản mô hình thực tế vận hành tại thời điểm gửi yêu cầu.
Phiên bản chỉ dẫn	Phiên bản của tài liệu quy định chỉ dẫn hệ thống và khuôn mẫu yêu cầu người dùng.
Danh mục bản ghi ngữ cảnh	Danh sách các bản ghi dữ liệu được trích xuất hợp lệ làm căn cứ đầu vào cho mô hình.
Đo lường dung lượng xử lý	Số lượng thẻ từ đầu vào và đầu ra phục vụ công tác giám sát hiệu năng và kiểm soát hạn ngạch.
Trạng thái phản hồi	Kết quả xử lý phiên gọi: Thành công, Sai định dạng cấu trúc, Vượt thời gian chờ, hoặc Kích hoạt chế độ dự phòng.
Quyết định phê duyệt con người	Hành động can thiệp của chuyên viên quản trị: Chỉnh sửa trực tiếp, Phê duyệt, Từ chối kèm lý do hoặc Hủy bỏ.

B.3. Nhật ký tương tác AI qua bốn mốc chu trình phát triển

Tuân thủ định hướng của Đề tài 80300 (Học phần AIA331), việc ứng dụng trí tuệ nhân tạo được triển khai xuyên suốt toàn bộ chu trình phát triển phần mềm (SDLC) theo phương châm con người giữ quyền quyết định tối hậu (*Human-in-the-loop*). Bảng B.3 tổng hợp quá trình tương tác, đối sánh giữa đề xuất ban đầu của mô hình, các hạn chế kỹ thuật phát hiện và phương án tinh chỉnh thực tế của sinh viên.

Bảng B.3: *Nhật ký minh chứng tương tác AI qua 4 mốc phát triển phần mềm (SDLC)*

Mốc SDLC	Nhiệm vụ & Chỉ dẫn đầu vào	Đề xuất của AI & Khiếm khuyết phát hiện	Quy trình kiểm chứng & Hiệu chỉnh thực tế
KT1 (Phân tích & Thiết kế)	Thiết kế lược đồ quan hệ cho các phân hệ nghiệp vụ quản lý chiến dịch và tương tác AI.	Mô hình đề xuất thiếu bảng lưu vết kiểm toán tương tác AI; khóa chính bảng chỉ số dễ trùng lặp khi ghi nhận dữ liệu nhiều kênh trong cùng một ngày.	Bổ sung bảng lưu vết kiểm toán với đầy đủ trường định danh, phiên bản chỉ dẫn và phản hồi con người; thiết lập khóa ngoại kép và ràng buộc duy nhất.
KT2 (Hiện thực hóa & Xử lý lỗi)	Xây dựng thuật toán tính toán chỉ số hiệu quả chuyển đổi và tỷ lệ hoàn vốn tiếp thị.	Mô hình đưa ra công thức chia trực tiếp giữa lượt tương tác và lượt hiển thị, dẫn đến lỗi chia 0 khi chiến dịch mới chưa phát sinh tương tác; thiếu kiểm tra quyền.	Bổ sung điều kiện kiểm tra biên an toàn trước khi thực hiện phép chia; tích hợp cơ chế bảo vệ phân quyền theo vai trò quản lý và phạm vi bản ghi.
KT3 (Chỉ dẫn & Kiểm thử biên)	Thiết kế mẫu chỉ dẫn trích xuất ý tưởng và kiểm thử với các bản tóm tắt chiến dịch dài.	Phản hồi của AI vượt ngưỡng độ dài dẫn đến đứt gãy JSON; xuất hiện hiện tượng tự suy diễn các chương trình khuyến mãi không có trong ngữ cảnh ban đầu.	Áp dụng cơ chế tóm lược dữ liệu theo trọng số ưu tiên; thiết lập quy tắc cứng cấm suy đoán ngoài dữ liệu; bổ sung bộ kiểm định Pydantic v2 nghiêm ngặt.
Cuối kỳ (Đóng gói & Vận hành)	Đóng gói container hóa toàn bộ hệ thống phục vụ triển khai trên môi trường phân tán.	Cấu hình mặc định sử dụng quyền root tiềm ẩn nguy cơ mất an toàn; kích thước gói giao diện quá lớn do chứa cả môi trường biên dịch Node.js.	Chuyển đổi dịch vụ sang tài khoản phi đặc quyền (UID 1001); áp dụng đóng gói đa tầng (Multi-stage Build) giúp giảm 98% dung lượng ảnh xuống $\sim$24,8 MB.

B.4. Đánh giá chất lượng mã nguồn và tối ưu hóa an ninh (AI Code Review)

Nhóm phát triển đã áp dụng quy trình rà soát mã nguồn kết hợp phân tích tĩnh theo khung tiêu chuẩn OWASP API Security và tối ưu hóa truy vấn SQL (Bảng B.4).

Bảng B.4: *Kết quả đánh giá chất lượng mã nguồn và tối ưu hóa an ninh (AI Code Review)*

STT	Hạng mục rà soát	Khiếm khuyết ban đầu	Giải pháp kiến trúc đã áp dụng	Hiệu quả đạt được
1	Bảo vệ khóa bí mật & Lọc nhật ký	Khóa kết nối dịch vụ ngoại vi đọc phân tán; nguy cơ lộ khóa rõ khi in log lỗi mạng.	Mã hóa khóa BYOK bằng Fernet AES-128; cài đặt bộ biến đổi che mặt nạ chuỗi nhạy cảm (chỉ giữ 4 ký tự đầu/cuối).	Bảo vệ 100% khóa bí mật; khử hoàn toàn rò rỉ trên tệp nhật ký.
2	Phân quyền vai trò & Phạm vi bản ghi	Các tuyến xóa chiến dịch và duyệt nội dung ban đầu thiếu kiểm tra chéo trạng thái tài khoản và phạm vi sở hữu.	Tách biệt tầng xác thực JWT và tầng thẩm định RBAC + Record-level Scope (`CampaignMember`).	Chặn 100% hành vi leo quyền dọc và ngang (IDOR) với mã 403.
3	Tối ưu hóa truy vấn CSDL quan hệ	Lấy danh sách chiến dịch kèm chỉ số hiệu suất dùng vòng lặp tuần tự gây hiện tượng truy vấn lặp $N + 1$.	Tái cấu trúc sang phép kết nối ngoài (`OUTER JOIN`) kết hợp gom nhóm `GROUP BY` trực tiếp tại động cơ CSDL.	Độ trễ P95 giảm từ 1.240 ms xuống 18 ms (nhanh hơn 68,8 lần).

PHỤ LỤC C.
HƯỚNG DẪN CÀI ĐẶT, CẤU HÌNH VÀ ĐÓNG GÓI TRIỂN KHAI

C.1. Quy trình thiết lập môi trường và vận hành tiêu chuẩn

Quy trình khởi tạo và đưa hệ thống MarketFlow AI vào trạng thái sẵn sàng phục vụ kiểm thử nghiệm thu được chuẩn hóa qua 4 bước tuần tự trong Bảng C.1.

Bảng C.1: *Quy trình 4 giai đoạn thiết lập, nạp dữ liệu mẫu và vận hành hệ thống*

Bước	Phân hệ	Thao tác / Lệnh thực thi tiêu chuẩn	Kết quả đầu ra kiểm chứng
1	Môi trường Backend	Cài đặt gói phụ thuộc Python 3.11 trong môi trường ảo cô lập (`pip install -r requirements.txt`).	Thiết lập đồng nhất thư viện FastAPI, SQLAlchemy 2.0, Pydantic v2, Cryptography.
2	Cơ sở dữ liệu & Seed Data	Khởi tạo lược đồ 11 bảng 3NF (SQLite WAL) và chạy script `init_db.py` nạp dữ liệu mẫu.	Nạp sẵn tài khoản Manager/Marketer, 4 chiến dịch, 14 nội dung, 60 bản ghi metrics.
3	Máy chủ API & Giao diện Web	Khởi chạy Backend (`uvicorn app.main:app --port 8000`) và Frontend (`npm run dev` tại cổng 5173).	Hệ thống phục vụ đầy đủ giao diện Bento Grid, AI Studio và Swagger UI (`/docs`).
4	Kiểm thử Tự động	Thực thi bộ kiểm thử `pytest backend/tests -q` trên CSDL in-memory cô lập.	Vượt qua toàn bộ 205/205 ca kiểm thử tự động (100% Pass, 0 Warnings).

C.2. Danh mục tham số cấu hình môi trường (`.env.example`) và Đóng gói Docker

Toàn bộ tham số nhạy cảm và cấu hình đóng gói đa tầng (`Dockerfile`, `docker-compose.yml`) được quản lý tập trung theo Bảng C.2.

Bảng C.2: *Đặc tả tham số môi trường trọng yếu và kiến trúc đóng gói Container*

Tham số / Thành phần	Giá trị / Cấu hình chuẩn	Vai trò kỹ thuật và Chính sách an ninh
`DATABASE_URL`	`sqlite:///./marketflow.db`	Kết nối CSDL SQLite kích hoạt tự động `PRAGMA journal_mode=WAL` và `foreign_keys=ON`.
`SECRET_KEY` & `ALGORITHM`	Chuỗi 256-bit / `HS256`	Khóa ký số JWT Bearer Token và khóa dẫn xuất PBKDF2-HMAC-SHA256 cho BYOK Vault.
`GEMINI_API_KEY` & `AI_TIMEOUT`	Khóa AI Studio / `10s`	Khóa kết nối mặc định tầng môi trường (Tier 3) và ngưỡng ngắt mạch tự động chuyển sang Smart Fallback.
Container Backend (`:8000`)	`python:3.11-slim` (UID 1001)	Vận hành dưới tài khoản phi đặc quyền; tích hợp `HEALTHCHECK` định kỳ 30 giây và gắn kết ổ đĩa bền vững.
Container Frontend (`:80`)	Multi-stage Build + `nginx:alpine`	Biên dịch tĩnh TypeScript/Vite ở tầng 1 và phân phối qua Nginx ở tầng 2 (giảm 98% dung lượng ảnh xuống ∼24,8 MB).